TLP:CLEAR



Continuous Diagnostics and Mitigation (CDM) Program Architecture

CDM Data Model Document

Version 6.0.1

Publication: September 2026
Cybersecurity and Infrastructure Security Agency

This document is marked TLP:WHITE. Recipients may share this information without restriction. Information is subject to standard copyright rules. For more information on the Traffic Light Protocol, see https://www.cisa.gov/tlp.

TLP:CLEAR

Revision Summary

Below is a table of changes that describes specific changes to this document since the last version, including references to the changed sections/paragraphs. For more details on the changes included in the most recent revision, please refer to Appendix C.

Version	Document Date	Revised by	Description of Change
0.1	August 2016	APL	Initial Draft – Released to DHS for additional content.
0.6	August 2016	CDM PMO	Added additional guidance and content for PMO review.
0.7	August 2016	CDM PMO	Made changes after JHU and PMO discussions/comments.
0.8	September 2016	CDM PMO	Made additional changes after JHU and PMO discussions on 9/8.
1.0	September 2016	CDM PMO	Prepared for release, updated interrogation specs and Conceptual Model included.
1.1	November 2016	CDM PMO	Incorporated feedback and edits from stakeholders, released.
2.0	April 2017	CDM PMO/APL	Added Phase 2 entities, attributes. Error corrections. Updated key sections to account for CDM Phase 2. Revised Phase 1 items.
2.1	June 2017	CDM PMO/APL	Feedback solicited from CDM stakeholders, incorporated into model. Clarified Interrogation Specifications for Phase 2 to be more consistent with FISMA metrics. Added additional content to key terms and guidance sections.
3.0	February 2018	CDM PMO/APL	Added new entities to support Incident Response Reporting, POAMs, Physical Locations (Facilities). Edited some existing entities to normalize data (e.g., Device Responsibility for device managers, providers, operators). Added Tool/Sensor metadata. Added AWARE data elements.
3.1	May 2018	CDM PMO/APL	Feedback solicited from CDM stakeholders, incorporated into model. Updated/added interrogation specifications for Phase 3 while updating previous Phase 1/2 to be in alignment with LDM edits.
3.5	July 2018	CDM PMO/APL	Derived data entities and attributes to in order to ensure alignment of the program's data requirements to the mission needs regarding Ongoing Assessment for Phase 1 (OAS). Updated/Added additional key definitions for Phase 2 terms. AWARE derived sub-scoring and aggregate scoring attributes. Added requested Data Attributes: Device Make/Model.

Version	Document Date	Revised by	Description of Change
			Changed ConfigurationSettingsOnNetwork to MisconfigurationOnNetwork. Added additional entity/attributes: DeviceScan, OASControlMeasurement, SecurityControl, ManagedAppOnNetwork.
3.7	August 2019	CDM PMO/APL	Identified changes associated with NAC, mobile, and CyHy updates. Updated design of ports, protocols, and services entity. Introduced threat intelligence entity. Added specialization/generalization to LDM design. Added more detailed "release notes" section (Appendix C).
3.8	January 2020	APL	Added and modified entities/attributes for: BOUND-E Certificate. Management capabilities, FISMA metric changes based on FISMA FY19, Policy Decision Point (PDP) architectural changes.
3.8.1	March 2020	CDM PMO	Finalized Draft (3.8.1) based upon feedback/comments. Published.
4.0	March 2022	APL	Added attributes and interrogation specifications supporting Data Quality Assessments and Data Effectiveness Assessments. Clarified Required data, Conditionally Required data, and Recommended data. Updated to fiscal year (FY) 2021 FISMA metrics.
4.1	August 2022	CDM PMO/APL	Updates and changes to System/System Boundary around authorization decisions, system names, HVA flags and subsystems. Updates to Vulnerabilities to capture more details that are available through tools and sensors.
5.0	June 2024	CDM PMO/APL	Updates to align with latest FY23 FISMA Metrics, which included major changes to metrics and query considerations.
6.0	September 2026	CDM PMO/APL	Continued deprecation of CPE elements; deprecation of CCE elements; deprecation of MUR and IDAM modeling (i.e., ACCOUNT, BEHAVE, CRED, PRIV, TRUST, User); deprecation of Entitlement; Addition of external data feeds (i.e., update of CyHy, addition of ASM NMI, SCuBA, and VDP).

1 INTRODUCTION 5
1.1 Purpose 5
1.2 Scope 5
1.3 Audience 6
1.4 Context for the Model Derivation Process 6
2 CDM GUIDANCE IN INTERPRETING THE DATA MODEL 9
2.1 CDM Datasets 9
2.2 Relational Structure and Implications 10
2.3 Specialization/Generalization 12
2.4 Multivalued Attributes 14
2.5 Master Device Record: Unique Identification of Hardware Devices 15
2.6 Creating a Software Inventory: Unique Identification of Software 15
2.7 Managed Applications: Risk Accountability Based on HWAM and SWAM Datasets 16
2.8 Creating the Master Incident Record: Tying Incidents, Related Events, Actors, and Activities Together 17
2.9 Organizational Unit Containers (Organizational Unit Boundaries) 19
2.10 FISMA System Containers (System Boundaries) 19
2.11 CVE 20
2.12 CyHy "Findings" Datasets 20
2.13 ASM Datasets 21
2.14 SCuBA Datasets 21
2.15 VDP Datasets 21
2.16 Threat Intelligence Within CDM 21
2.17 CDM-Required Data 21
3 DATA MODEL KEY TERMS 22
4 DATA DICTIONARY FOR THE LOGICAL DATA MODEL 32
APPENDIX A: REFERENCES 66
APPENDIX B: THREAT ACTION VALUES 68
APPENDIX C: RELEASE NOTES FOR THIS VERSION 80

Table of Contents

1 INTRODUCTION

1.1 Purpose

The Cybersecurity and Infrastructure Security Agency (CISA) Continuous Diagnostics and Mitigation (CDM) program operates on the premise of a common architecture that relies on capabilities provided by commercial-off-the-shelf (COTS) tools and sensors. In keeping with that approach, the CDM program has identified a need to overlay similar data requirements on the solution to ensure that common program objectives are met and to provide proper clarity to integration needs. This document outlines fundamental data elements that the program expects each CDM solution deployed at agencies to incorporate.

The data model identifies the minimum set of data requirements needed to leverage the CDM solution to accomplish the program's objectives: to reduce agency threat surface, increase visibility into the federal cybersecurity posture, improve federal cybersecurity response capabilities, and streamline Federal Information Security Modernization Act (FISMA) reporting.

Additionally, this document delivers guidance regarding the data that CDM solutions at agencies must collect, with an explicit understanding that the system will be required to produce datasets from specific interrogations of the CDM data. It is expected that agencies and CDM integrators will enrich these datasets with other relevant Information Security Continuous Monitoring (ISCM) data that fulfill their agency-specific needs.

CDM integrators should use this document to drive development and refinement of the implementation of the holistic solution, incorporating these data requirements into the operational rhythm of security tools and sensors. This will provide data to facilitate the execution of the CDM program's mission objectives.

1.2 Scope

The data requirements discussed in this document represent the minimum required dataset to accomplish the critical objectives of CDM, as foreseen by the CDM Program Management Office (PMO), across different solutions, while achieving consistent results. Currently, the scope is focused on data requirements related to the technical capabilities found under "Asset Management" (formerly Phase 1), and "Network Security Management" (formerly Phase 3). Detailed operational capabilities are found under the following decomposed tool functionalities:

- Asset Management (including mobile devices) [formerly known as Phase 1]
    - Hardware Asset Management (HWAM)
    - Software Asset Management (SWAM)
        - Application Execution Control (AEC)
    - Configuration Settings Management (CSM)
    - Vulnerability Management (VUL)
    - Enterprise Mobility Management (EMM
        - Mobile Threat Defense (MTD)
- Network Security Management [formerly known as Phase 3]
    - Manage Events (MNGEVT)

        - Incident Response
        - Ongoing Assessment (supporting Asset Management data only)
    - Operate, Manage, and Improve (OMI)
        - System and Information Integrity (supporting incident response)
    - BOUND-E
        - Certificate Management (non-person entities only)
    - BOUND-F to Manage Network Filters and Boundary Controls
        - Network Access Protection

It is anticipated that additional content will be incorporated in subsequent iterations of this artifact as new technical capabilities are added to the CDM program operational baseline.

CDM's conceptual architecture and associated security frameworks, which convey program needs through CDM Technical Capabilities, Volume 1 and Volume 2, are also used to derive necessary data requirements that are reflected in this model. Specifically in scope are the definitions of the logical groupings of key cybersecurity information in the following constructs:

- Master Device Records (MDRs)
- Master Incident Records (MIRs)
- FISMA and Organizational Unit (OU) Containers

The CDM datasets included are decomposed into entities and attributes within the interrogation specifications section. They provide strong traceability for data requirements laid out for agencies (i.e., "must have" data).

Finally, it is important to note that physical schemas and as-built designs are largely out of scope of this document. It is the CDM dashboard developer's responsibility to develop and align the physical data schema (i.e., CDM "data target") to the intent of this logical model through the requirements and solution engineering activities within the program.[1]

1.3 Audience

This document's intended audience is assumed to have a working knowledge of the CDM program. The audience primarily includes CISA Cybersecurity Division staff,[2] CDM participating agencies' staff, CDM Dynamic and Evolving Federal Network Defense (DEFEND) integrators, and the CDM dashboard provider.

1.4 Context for the Model Derivation Process

CDM is:

- **A process** within an agency's ISCM strategy, as originally mandated in the Office of Management and Budget (OMB) Memorandum (M) 14-03[3] (since superseded by later OMB cybersecurity memoranda), to strengthen the security posture of the federal civilian networks by enabling operators to continuously search for flaws, collect results, triage and analyze results, fix the worst flaws first, and report progress.

[1] For more information on how to use and interpret this document, refer to the guidance within Section 2.
[2] Specifically, this includes CISA Cybersecurity Division staff who support operationalization or oversight of the CDM program.
[3] "Enhancing the Security of Federal Information and Information Systems," M-14-03, November 18, 2013. https://obamawhitehouse.archives.gov/sites/default/files/omb/memoranda/2014/m-14-03.pdf.

- **A program** that provides continuous monitoring, diagnosis, and mitigation capabilities by centrally coordinating the procurement, installation, operation, and maintenance of diagnostic sensors (tools) and dashboards deployed to participating agencies and a federal-level cyber diagnostic dashboard maintained at the Department of Homeland Security (DHS).
- **A system** consisting of multiple instantiations of tools and dashboards that work together to enable the CDM process.

The CDM Data Model is a **common schema** of data elements and attributes based on recommendations and requirements conveyed in the CDM architecture. This common schema is authoritative in developing the data requirements for the CDM program and represents the to-be state of the data both within (as ingested and stored) and outside of (as queried and reported) Layer C of the CDM architecture (see Figure 1-1). With regard to data queried or reported, a core set of **data interrogation actions** were captured based on input from various sources that were solicited in developing this artifact, including the CDM[4],☐ Volume 1 and Volume 2 and the Chief Information Officer (CIO) Federal Information Security Modernization Act (FISMA) Metrics. In the case of FISMA metrics, this document focused on information that could be specifically tied to CDM assets, identity and access, network security, and data management capabilities (formerly Phase 1, 2, 3, and 4 security capabilities, respectively). Each data interrogation action represents key fundamental mechanisms of the CDM solution, satisfying mission requirements for summary reporting, scoring, and/or defect prioritization.

The cohesive philosophy of normalizing metrics and key machine information is required to facilitate a standard CDM dashboard platform across all agencies (representing the aforementioned "Layer C" of the architecture as shown below). As one of the central aspects of CDM, the dashboard serves as the primary means by which the CDM Logical Data Model (LDM) can be physically implemented. Through the development and deployment of the CDM agency dashboard, a physical schema ("as-built" by the dashboard developer), which is aligned to the intent and requirements of the LDM, provides the realized vision of a normalized CDM dataset (i.e., common schema).

Leveraging this architecture, the federal dashboard collates the summary information and risk scores produced by the multiple agency dashboards to enable standardized, comprehensive cyber visibility into the entire civilian government enterprise. This CDM dashboard hierarchy represents the operationalization of the data architecture within this artifact. The dashboard allows for the common schema to be enumerated and queried at each agency, with the results providing stronger cybersecurity measurements across the agencies.

We developed the CDM Data Model and attributes[5] described in this document using the following process:

1. Enumerate all relevant data interrogation actions linked to one or more of the key reference materials
2. Create specifications for each data interrogation action identified in a fully defined, common standard format (e.g., SQL[6]).
3. Derive data entities and attributes to meet these specifications (i.e., a common schema for CDM technical capabilities).
4. Develop a data dictionary to describe entities and attributes clearly.

[4] These documents describe the requirements for the CDM program that are consistent with the overarching goal of enabling U.S. government entities to assess and improve the security posture of an agency's information systems. These requirements will be used for the CDM solicitations called Dynamically Evolving Federal Enterprise Network Defense (DEFEND) program as well as the Schedule 70 CDM-SIN Approved Product List (APL).

[5] Refer to Section 2 for more information regarding Unified Modeling Language (UML) entity relationship (ER) diagraming, entities, and attributes.

[6] Structured Query Language (SQL) is a special purpose language for accessing data in databases. In this case, it is a well-known formal language that can be used to specify the interaction of the data interrogation action with the object data within the CDM system.

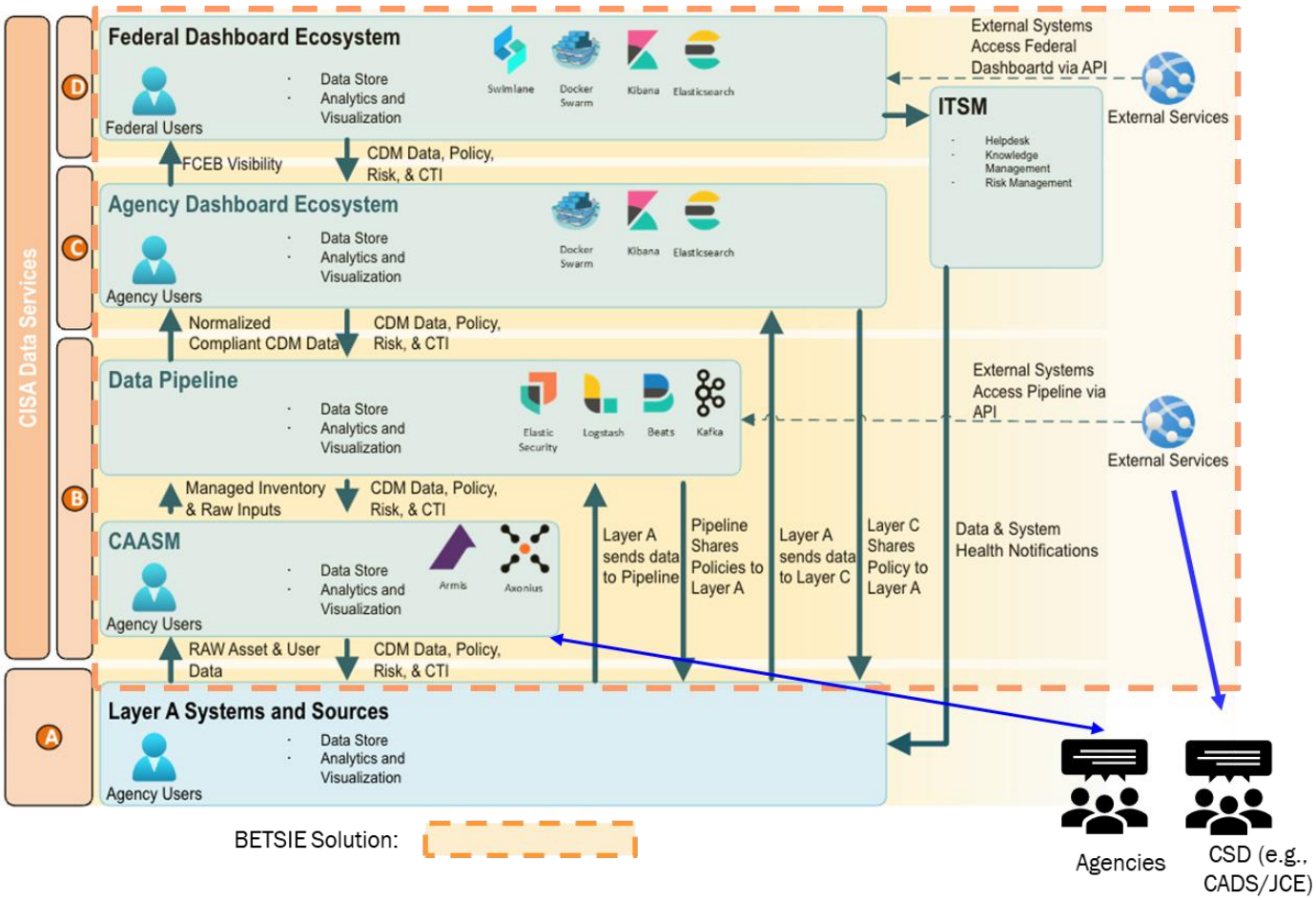


Figure 1-1: CDM "ABCD" diagram showing the distinct layers of the architecture. The CDM Data Model focuses on the interface between layers B and C, clarifying the common datasets to be provided by B aligned to expected inputs in C.

2 CDM GUIDANCE IN INTERPRETING THE DATA MODEL

This section provides guidance on practices and principles that are necessary to support the consistent adoption and use of the CDM Data Model and its related artifacts (e.g., the Logical Data Model [LDM] itself). The guidance relevant to the CDM program will change over time as the scope of the program expands to provide more capability and coverage.

The LDM is compatible with previous conventions that outline the data modeling process (e.g., DoDAF DIV-2). Some of the fundamental underpinnings of a logical model are that it "allows analysis of an architecture's data definition aspect, without consideration of implementation-specific or product-specific issues," and that it is intended "to provide a common dictionary of data definitions to consistently express models wherever logical-level data elements are included in the descriptions."[7]

The program uses these documents—CDM LDM and Data Model Document— for two main purposes:

1. These documents explain the data requirementsfor the CDM common schema and guide thethe dashboard developerand DEFEND integrators in building the system.
2. These documents provide clear definitions of key terms, attributes, concepts, and how datasets must relate to each other during implementation.

Note: This CDM Data Model Document is part of a collective set of artifacts that are intended to be used together to achieve the goals outlined in Section 1 of this document. Specifically, this document should be reviewed in conjunction with **CDM_LDM_[VerNO].png**, which provides the LDM itself in a visually based Unified Modeling Language (UML)-entity relationship (ER) structure.

2.1 CDM Datasets

CDM datasets may be categorized as follows:

- **CDM Effectiveness Measures** – Datasets that help analysts assess how well CDM subsystems work. Examples include CSM and VUL scan timeliness and configuration checks.
- **Inventory Metadata** – Datasets that characterize CDM container inventories. Examples include inventories of installed software, devices, and privileged users per system boundary and per organizational unit.
- **CDM-Defined Defect Checks** – Datasets that periodically compare an object's actual state (as derived from sensors) with the desired security state (as established by policy). Examples include unauthorized device, unauthorized software, and vulnerable devices.
- **Ongoing Assessment and Monitoring** – Datasets that are directly traceable to information security frameworks, such as the Risk Management Framework (RMF), the Cybersecurity Framework (CSF), and/or the MITRE ATT&CK® framework.
- **FISMA CIO Reporting Data** – Datasets that support the FISMA metrics survey [fiscal year (FY) 2025 CIO FISMA Metrics], which specifies required reporting for all federal agencies in order to demonstrate effectiveness in strengthening federal cybersecurity through policy and practices.

Some datasets are intended for future integration into the CDM system but are still theoretical (i.e., non-operational) and have not been baselined into the program's requirements.

[7] "DoDAF Viewpoints and Models, Data and Information Viewpoint, DIV-2: Logical Data Model," U.S. Department of Defense, accessed August 17, 2023, https://dodcio.defense.gov/Library/DoD-Architecture-Framework/dodaf20_div2/.

2.2 Relational Structure and Implications

The LDM used in this document is a UML-based entity relationship diagram (ERD). It includes the key data elements that the CDM Program Management Office (PMO) has identified as necessary for a minimally effective CDM solution. As with any ERD, the LDM is built around two main components: *entities* and *attributes.*

- Entities are principal objects (subjects) between which relationships are established; typically, they facilitate the capture of important datasets. Entities are commonly thought of as "tables" or "classes" in data design, although this document exclusively uses the term "entity."
- Attributes represent the detailed properties of each entity, which facilitate describing, through data, the unique characteristics of an instance of that entity. Each entity is normalized to feature the same type of attributes, and each instance of an entity may have different values for those attributes. For example, if **DeviceOnNetwork** represents an entity with attributes of **DeviceCategory**, **DeviceFQDN**, and **DeviceType,** the unique properties of each device are inventoried in a "device collection" for the CDM solution. It is important to note that relationships between entities may feature attributes that describe the characteristics of that relationship, and not all attributes are equal (e.g., some can be used as unique identifiers and some can be multivalued). The data dictionary in this document provides additional guidance regarding differences between entities and attributes, including the type and use of attributes.

Along with the LDM, this document explains the CDM program's mission needs, including the required business processes, relationships, and the level of detail needed for collected data. It does not provide or describe a physical data model and therefore does not depend on any specific technical implementation. Even though CDM solutions may not use a traditional relational database structure to store data or run searches, they must still generate results that reflect the relationships described in this document.

The way the data elements and their relationships are shown creates the linkages that the CDM PMO uses to produce information for agencies and oversight organizations such as OMB.

As noted earlier, this document supports the LDM and does not fully break down every relationship among all entities, as a physical data model in a relational database would. In particular, many of the many-to-many relationships between entities—where instances from both entities can relate to multiple instances of the other—are represented through *implied* associative (cross-reference) tables. These tables use the primary keys from each related entity to form a combined logical primary key made from two foreign keys. These kinds of tables appear in the interrogation specifications and are identified where appropriate for the reader's consideration.

When an implied associative table contains additional attributes that need clear definition, those attributes are formally represented in the LDM. For example, Figure 2-1 in the CDM LDM shows a many-to-many relationship between the **DeviceOnNetwork** and the **UniqueSoftware** entities. In this case, the associative table is explicitly modeled rather than implied. The additional attributes required for this relationship are included in the LDM and documented in the data model to ensure clarity and completeness.



Figure 2-1: Many-to-many relationship between DeviceOnNetwork and UniqueSoftware with a "realized" implied table [SoftwareInstalledOnDevice]

2.3 Specialization/Generalization

Specialization is the process of describing a set of *subclasses* of an entity. The set of subclasses that form a specialization describes a distinguishing set of characteristics of the entity, which is the *superclass.* Examples of specializations in the CDM LDM include **ToolSensorDeviceOnNetwork** and **MobileDeviceOnNetwork**, which are specializations of the superclass **DeviceOnNetwork**:

- A **MobileDeviceOnNetwork** describes a type of **DeviceOnNetwork** (i.e., a mobile device is a category of devices that is captured as part of a system). The distinguishing characteristic of the device entity that describes this specialization is a device category of mobile devices. Similarly, **ToolSensorDeviceOnNetwork** describes a specialization of a **DeviceOnNetwork** serving in a particular CDM security capability-based role (i.e., a device that serves in the role of sensing devices, vulnerabilities, or misconfigurations on the network).
- A specialization is typically used in data modeling to capture a special set of attributes that are specific to a subclass but share all other attributes with the superclass. In the **ToolSensorDeviceOnNetwork** example specialization, a tool/sensor device has many of the attributes a generic device has, but it also has tool/sensor-specific attributes (e.g., **ToolSensorType**, **ToolSensorVersion, ToolSensorProduct, ToolSensorVendor, ToolSensorUpdate,** and **NVDLastUpdateDate**).
- A specialization may also capture a special relationship the subclass entity has with another entity that the superclass entity does not. In the **MobileDeviceOnNetwork** example, a mobile device relates to a user in a way that a generic device does not; it captures the user that a mobile device is assigned to. Therefore, there is a unique relationship between **MobileDeviceOnNetwork** and **User** that does not exist between **DeviceOnNetwork** and **User**.

Generalization is the reverse of specialization, where the differences among a set of entities are suppressed and their common features are captured in a generalized entity. For example, the **DeviceOnNetwork** entity can be viewed as a generalization of **ToolSensorDeviceOnNetwork** and **MobileDeviceOnNetwork**. While specializations and generalizations can be transformed into relations in different ways in database implementations (physical model), this document assumes, for ease of query construction, that specializations in relational implementations are being transformed into separate tables along with a table for the superclass within a relational database implementation. For example, refer to the interrogation specification ***Mobile Devices Without Full Device Encryption:*** *Use CDM to find the number of mobile devices without full device/disk encryption enabled.* This interrogation specification envisions a table **DeviceOnNetwork** and a table **MobileDeviceOnNetwork** to create the query that would satisfy the interrogation specification (see Table 2-1). An example of these modeling constructs can be seen below in Figure 2-2 for **DeviceOnNetwork**, **MobileDeviceOnNetwork,** and **ToolSensorDeviceOnNetwork**.

Table 2-1: CDM interrogation specification that illustrates the use of specialization MobileDeviceOnNetwork

Mobile Devices Without Full Device Encryption: Use CDM to find the number of mobile devices without full device/disk encryption enabled. **(CDM PMO)**	SELECT DeviceOnNetwork.SystemBoundaryID, COUNT(MobileDeviceOnNetwork.DeviceOnNetworkID) FROM DeviceOnNetwork INNER JOIN MobileDeviceOnNetwork ON DeviceOnNetwork.DeviceOnNetworkID = MobileDeviceOnNetwork.DeviceOnNetworkID WHERE DeviceOnNetwork.DeviceEncrypted = "FALSE" -OR- SELECT DeviceOnNetwork.SystemBoundaryID, COUNT(DeviceOnNetwork.DeviceOnNetworkID) FROM DeviceOnNetwork WHERE DeviceOnNetwork.DeviceCategory = "MOBILE DEVICE" AND DeviceOnNetwork.DeviceEncrypted = "FALSE"

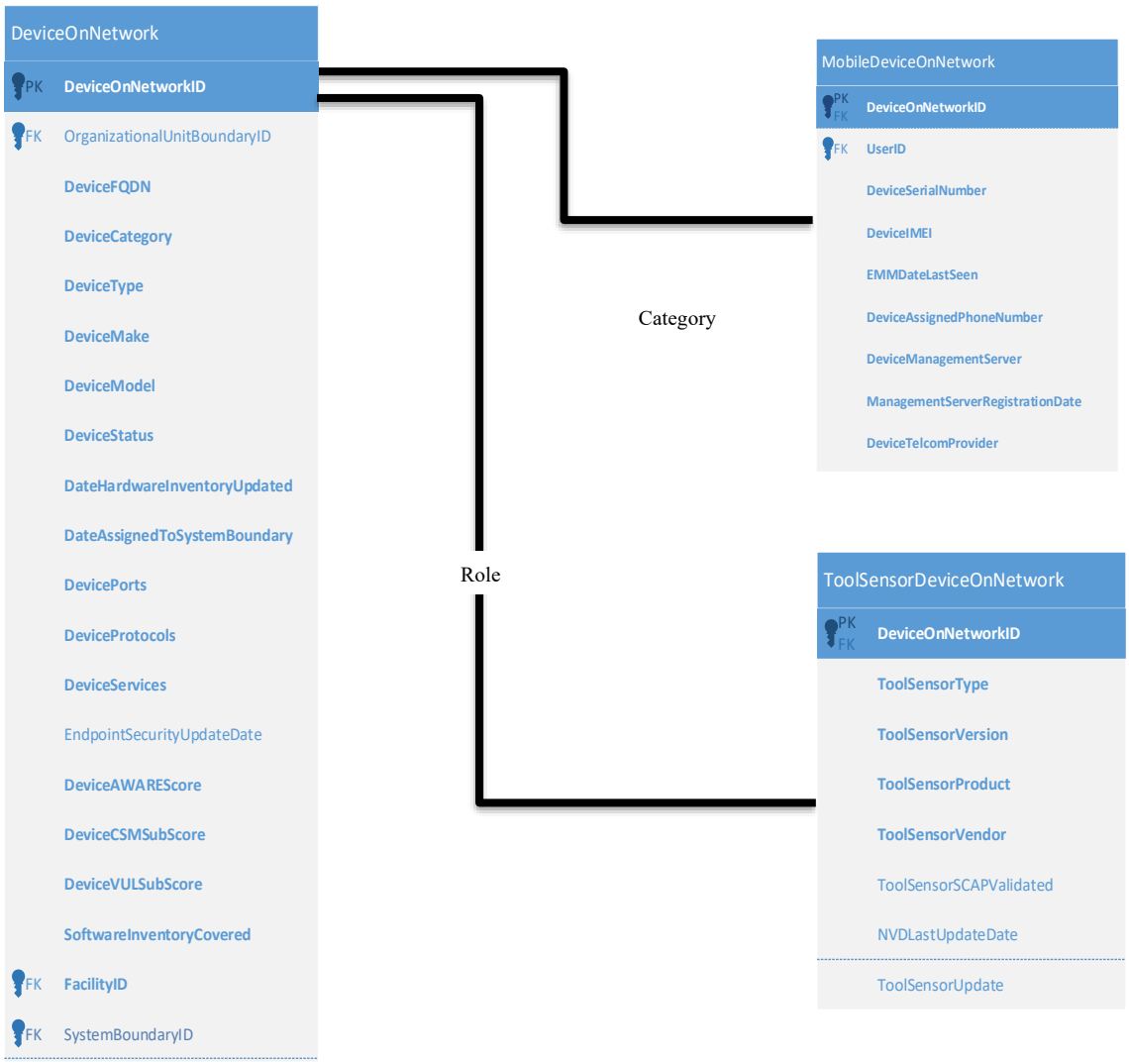
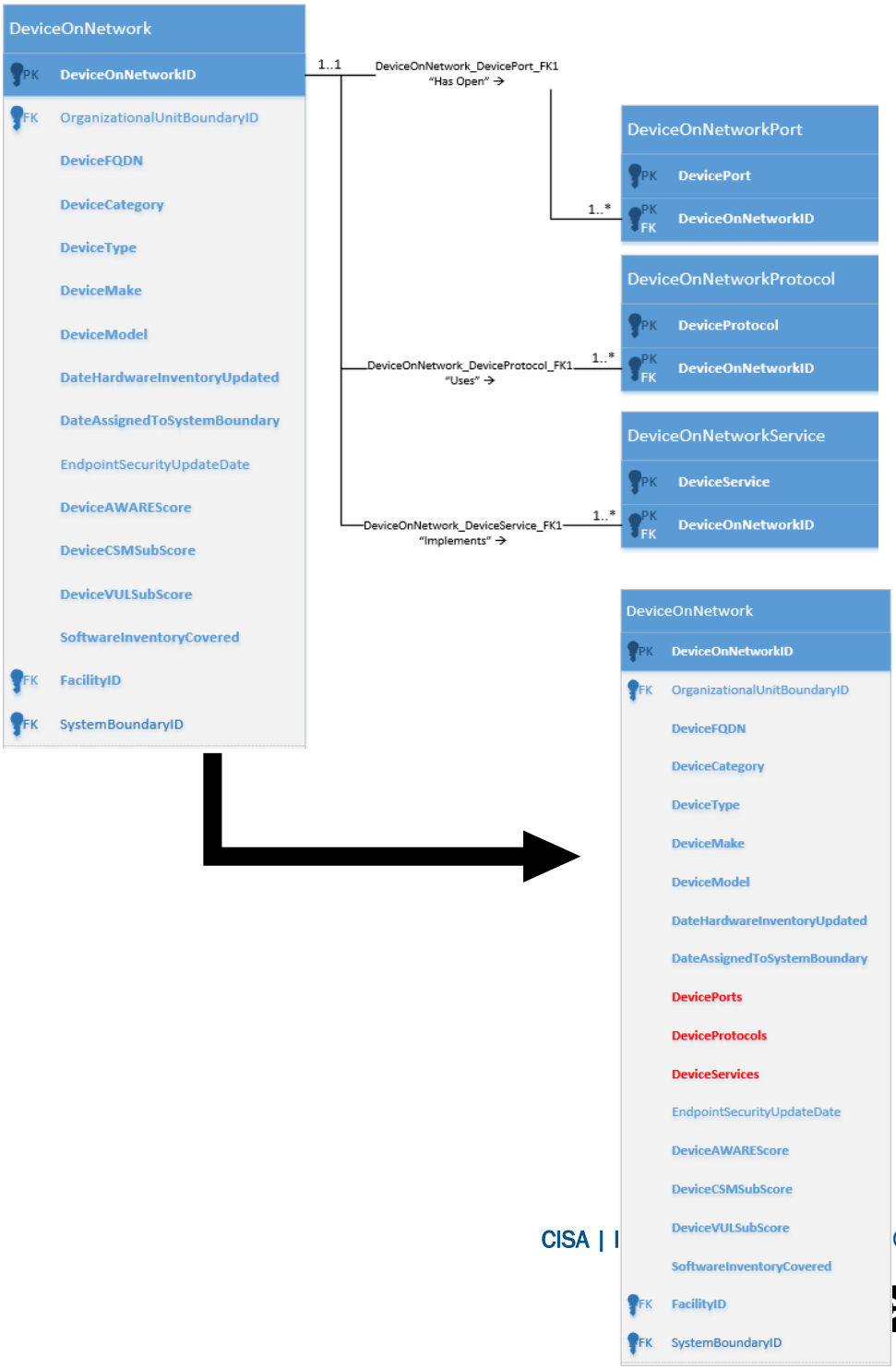


Figure 2-2: DeviceOnNetwork with specializations MobileDeviceOnNetwork and ToolSensorDeviceOnNetwork

2.4 Multivalued Attributes

Within each CDM Data Model entity, attributes represent a discrete, singular value or characteristic of an entity. In some cases, *multivalued* attributes represent relevant characteristics that can have multiple values instead of just one. An example of a multivalued attribute in the CDM Data Model is the **DeviceAssignedPhoneNumbers** attribute in the **MobileDeviceOnNetwork** entity. The mobile phone number may not typically be a singular value but rather 1 - n values representing one or more phone numbers assigned to the mobile device; therefore, it is modeled as a multivalued attribute. Multivalued attributes are typically transformed into relationships within relational physical data models. This typical transformation is reflected in the interrogation specifications involving multivalued attributes from the CDM LDM. See Figure 2-3.



2.5 Master Device Record: Unique Identification of Hardware Devices

The first phase of CDM is grounded in developing a comprehensive inventory of what is on the agency's network through the identification and discovery of IT assets. This allows for enumeration of fundamental CDM containers (i.e., organizational unit [OU] and FISMA containers) such that security policies and assessments can be conducted. To support this end state, the logical construct described as the master device record (MDR) was developed, enabling the CDM solution to group vital characteristics on each inventoried device in a way that can be uniquely referenced for determining desirable states for that device.

Elements of the MDR include attributes specified in the **DeviceOnNetwork** entity in addition to the CDM Asset Management capability attributes that have security relevance, which include discovered vulnerabilities (VUL), discovered misconfigurations (CSM), and installed software (SWAM). See Figure 2-4 for more information.

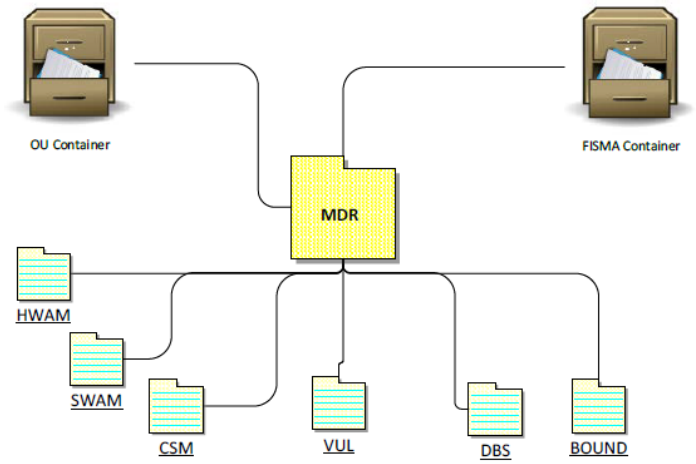


Figure 2-4: MDR illustrated: CDM Technical Capabilities Volume 1, Defining Actual and Desired States, version 1.1

To implement the MDR, the CDM program requires a CDM solution to be able to uniquely identify hardware devices within a department or agency (hardware unique identifier [UID]). The **DeviceOnNetworkID** field is stipulated in the CDM Data Model as a facilitator of this capability, allowing the association with a unique identifier (i.e., primary key) with a hardware asset once it has been identified within the CDM data that resides within the agency's CDM solution. The CDM Data Model does not prescribe the methodology for achieving this identification; the agencies and their CDM integrators must leverage the data on hand to achieve this. Relevant characteristics of IT assets that may be used to derive a UID include:

- Fully qualified domain name (FQDN)
- Globally unique ID assigned by OS or hypervisor (e.g., vCenter)
- Custom registry keys or data tokens that reside within the OS
- MAC addresses
- IP addresses (e.g., static management IPs or Dynamic Host Configuration Protocol-Bounded IPs)
- Hardware profile (e.g., presence of certain physical hardware)

Through the ability to uniquely identify hardware assets and the combination of required, reportable hardware attributes as prescribed in the CDM Data Model under the **DeviceOnNetwork** entity, the concept of the MDR can be realized.

2.6 Creating a Software Inventory: Unique Identification of Software

Another key requirement for an effective, secure CDM solution is its ability to discover software within an agency. Similar to the idea of the MDR, the CDM solution needs to filter through various software installations, including lower-level software components, such as binaries, executables, and other data points within the agency environment, to positively identify particular software products. This requirement, represented in the

LDM as the **UniqueSoftwareID** attribute, also necessitates the ability to determine variations between major and minor revisions while deduplicating the same software (rev/version) that may have slightly different common naming conventions in the system on which it operates (e.g., in the Windows registry).

The CDM solution is heavily dependent on unique identification of software products—also referred to as software configuration items (SWCI) in the CDM program's requirements—to determine vulnerabilities, configuration settings, and authorization of use. For the purposes of this data model and the expectations of the CDM program, the scope of software inventories focuses on distinguishing and classifying SWCIs (i.e., software products) and not software components, which represent much larger sets of files that are packaged or related together to comprise an SWCI that operates on an endpoint.

The CDM program expects CDM integrators to inventory all relevant software components using CDM tools and to normalize this raw data into relevant software product inventory data for the purposes of data ingestion into other layers of the CDM solution. In this manner, each CDM solution shall have the capability to allow end users to understand what software products are composed of what software components; however, tracking these relationships for upward reporting into the CDM agency dashboard is not expected.

The CDM Data Model does not specify how to uniquely identify software products, but the following characteristics can help:

- Hash values of executable code or related binaries
- Industry naming values:
    - Imprinted on install (e.g., Windows Registry)
    - Queried from management tool (e.g., IBM BigFix, Microsoft System Center)
    - Pulled from any associated configuration files
    - Queried from a package manager (e.g., RPM)
    - Retrieved from other interrogation methods

2.7 Managed Applications: Risk Accountability Based on HWAM and SWAM Datasets

Agencies manage IT assets at various levels of granularity as appropriate for the situation. This includes considering many factors, such as mission impact and accountability. In practice, it is common to have "split responsibilities" on devices and their associated software when agencies determine that certain applications have distinct business functions or operational requirements (e.g., FISMA System A has authority over the secure configuration of web software that resides on Device B, whose authority regarding secure configuration of the OS resides under the logical boundary of FISMA System B).

As part of implementing functionality that aligns with common agency practices, the CDM architecture allows for the risk management process of separating groupings of installed software into artificial management constructs. This construct is referred to as a "managed application" (**ManagedAppOnNetwork** in the LDM) and is instantiated using vital information from both HWAM (i.e., devices on the network) and SWAM (i.e., software on the network) inventories. Once codified, a managed application can then be associated with other security-relevant information produced from CDM tools/sensors, including CSM (misconfigurations) and VUL (vulnerabilities) datasets. This helps promote assignment of security risk accountability and keeps it aligned with agency policy, staff roles, and the principles of the NIST RMF.

Table 2-2: Examples of Interrogation Specifications for the Managed Application Concept

Data Interrogation Action	Interrogation Specification
Total "Managed Application" Count: Use CDM to find the number of actively managed applications within the organization's unclassified network(s). (Analogous to the **Total Hardware Assets** interrogation action)	SELECT ManagedAppOnNetwork.OrganizationalUnitBoundaryID, COUNT(ManagedAppOnNetwork.ManagedAppOnNetworkID) AS TotalManagedApplications FROM ManagedAppOnNetwork GROUP BY ManagedAppOnNetwork.OrganizationalUnitBoundaryID
Vulnerable "Managed Applications": Use CDM to find networks hosting vulnerable managed applications for which a patch or workaround may be needed. (Analogous to the **Vulnerable Devices** interrogation action)	SELECT ManagedAppOnNetwork.SystemBoundaryID, ManagedAppOnNetwork.ManagedAppOnNetworkID FROM ManagedAppOnNetwork INNER JOIN VulnerabilityOnNetwork ON ManagedAppOnNetwork.ManagedAppOnNetworkID = VulnerabilityOnNetwork.ManagedAppOnNetworkID GROUP BY ManagedAppOnNetwork.SystemBoundaryID

Agencies can instantiate managed applications by including discrete, inventoried software into an artificial entity that will share a common set of attributes (e.g., Namespace, Organizational/System Boundary Membership). This process logically segments applications with higher-level business functions from the supporting host OS or infrastructure on which it resides. This has a multifaceted benefit in that (1) there is an organic instantiation of risk inheritance to other supporting IT assets, which can be explicitly traced, and (2) managed applications can now serve as a potential anchor point for an itemized assignment of risk (e.g., vulnerabilities/misconfigurations) that is distinct from their host OSs or infrastructure. The result is traceability for security practitioners who have responsibility, authority, and, ultimately, motivation to take appropriate action.

Agencies, as part of their internal governance processes, can develop any number of these managed applications to accurately reflect the desired state of their IT asset inventory for assessment and authorization purposes. Due to the many similarities to devices from a data interrogation perspective, the CDM Data Model Document does not explicitly include managed applications in its queries. Where appropriate, the data interrogation specifications annotate which queries can be executed on the **ManagedAppOnNetwork** entity, making it transparent how the CDM datasets can be extended to support this concept. See Table 2-2 for examples of interrogation specifications that have been adapted to the managed application concept.

2.8 Creating the Master Incident Record: Tying Incidents, Related Events, Actors, and Activities Together

The master incident record (MIR) was conceptually architected to support the mission need of determining what, from a security incident relevant perspective, is happening on the network.[8] This capability is implemented by logically tying events, CDM-produced machine data, and containers together with activities and attributes that describe a suspected or confirmed security incident and the agency's response. This process allows for traditional, previously isolated reporting processes to be enriched by virtue of harmonizing

[8] NIST defines a computer security incident as "a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices." CDM uses the same common understanding in the definition of "incident" within this document.

incident information with other conceptual elements under CDM—such as Organizational Unit (OU) and FISMA containers and MDRs. The combination of these constructs can be fully leveraged to support existing reporting requirements within the .gov space as required by federal initiatives (i.e., CISA Federal Incident Notification Guidelines).

In the CDM LDM, the MIR is visually represented by relating entities such as incident (**IncidentOnNetwork**), events produced by agency tools **(EventOnNetwork)**, actions that have potentially detrimental impacts (**IncidentAction**), and the actors that contributed to the incident **(IncidentActor).** These information types are then contextually tied together with information under CDM device and user data to portray a holistic picture of potentially impactful occurrences that could reduce the security of a system or its assets. Additionally, the CDM Data Model tracks activities that are conducted in response to the incident through **ResponseActivity** entity, which models what critical steps may be taken by an agency to initiate containment, eradication, and/or recovery after confirmation of an incident. Finally, as part of collecting the salient attributes necessary to report the incident, any indicators (**IndicatorOfCompromise**) are documented and associated with the MIR.

It is critical to note that within the CDM architecture, the MIR and all associated entities and attributes will support incident response reporting at an elevated view that is not overly burdened by unprocessed, raw data—data that has not been refined, analyzed, and correlated to a suspected or confirmed incident (see **Event** in Data Model Key Terms section for additional context). To achieve this, lower levels of the CDM architecture (i.e., tool/sensor layers[9]) will be leveraged to implement CDM and agency-related policies that produce and correlate the information needed to establish sufficient evidence that anomalous or undesired activity is occurring within the network—activity that requires incident response and management.

This "processing" of raw event data to security actionable information is then recorded as an **EventOnNetwork** and provides the targeted, detailed information that is critical in the identification process of an incident on an agency's network. As an incident is codified and recorded, it is further investigated and analyzed to parse out the other related attributes and entities, including the actions that may have caused or been involved in the incident (**IncidentThreatAction**) and the actor who might have initiated the actions **(IncidentActor).**

[9] Tools and sensors provided under the capabilities within "Network Security Management" phase, such as "Manage Events (MNGEVT)," "Operate, Monitor, and Improve (OMI)," which includes products classified as SIEM tools, endpoint detection and response tools, IDS/IPS, etc., are anticipated to support the CDM architecture under this requirement.

2.9 Organizational Unit Containers (Organizational Unit Boundaries)

Standardizing the definition of the agency organizational structure is key to (1) providing OU context in support

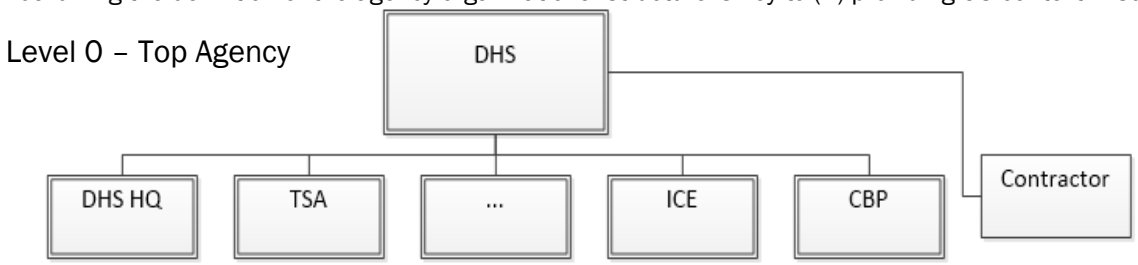


Figure 2-5: OU Hierarchy for the Department of Homeland Security

of risk posture scoring and (2) providing finer-grained identification of the OU policy parameters referred to within NIST Special Publication 800-53 definitions. The CDM solution requires that object-level data (e.g., IT assets/devices) be grouped into OU containers for reporting, policy mapping, and risk posture scoring. The CDM PMO requires an agency to minimally decompose its OU hierarchy and organize associated CDM objects to at least one level. Agencies may go beyond one level if desired, but the data will always be aggregated for reporting purposes to the federal dashboard to one level of depth. See Figure 2-5 for the DHS OU hierarchy decomposed to one level of organizational depth.

2.10 FISMA System Containers (System Boundaries)

FISMA system containers, also known as FISMA containers, information system, and/or system boundaries, represent a core organizational construction for the implementation of the CDM solution. This construction is informed by security artifacts, such as a system security plan, and represents a logical boundary for which common security controls and policies are applied to a grouping of related assets (e.g., networks, devices, and people) to accomplish some mission or business objective, per the NIST RMF.[10] The FISMA container should also be thought of as the authorization boundary for an information system for which security controls and Federal Information Processing Standards (FIPS) impact ratings apply.

[10] Identifying well-conceived information system boundaries is challenging but necessary for achieving the fundamental objectives of the CDM program. Agencies and integrators should refer to NIST Special Publication 800-37, "Guide for Applying the Risk Management Framework to Federal Information Systems" for additional guidance.

2.11 CVE

The CDM Data Model stipulates that the solution be capable of referencing a dictionary of well-documented standards for identifying software vulnerabilities. The anticipated process is that CDM-provided scanners will produce raw results that identify "defects" (e.g., vulnerabilities outside the baseline) that might not be natively standardized across industry using a common identifier. To normalize this data and provide relevant support information that is consistent with the CDM objectives of helping agencies find, prioritize, and address the "worst things first," the CDM program has engineered an information exchange mechanism between the CDM federal and agency dashboards. This "flow down" of information shall provide the following standardized information:

- A content dictionary of all common vulnerabilities and exposures (CVEs) and their related scoring parameters for the CDM program, represented as the **CVEDictionary** entity in the data model.

The CDM program expects that updates to information, such as CVEs, will disseminate on a recurring schedule to ensure all agencies have the latest, consistent dictionary of these standards. The CDM federal dashboard will continue to derive updates based upon a combination of external sources, such as:

- National Vulnerability Database (NVD) data feeds—including CVEs: (https://nvd.nist.gov/vuln/data-feeds)
- Industry available data (e.g., threat feeds, vulnerability reports)
- https://www.disa.mil/~/media/files/disa/news/conference/cif/briefing/ia_stig_scap_and_data_metrics.pdfCDM-specific derivation.

The CDM program requires that every agency's CDM solution maintain a comprehensive referential copy of all CVEs through this prescribed dashboard-to-dashboard information flow, to ensure that all discovered items within an agency have the proper baseline for indexing inventories and risk.

In some cases~~,~~ agencies will have an operational need to develop their own dictionary entries to properly identify, normalize, and report items in the CDM solution. This is acceptable and expected, with provisions made in the CDM agency dashboard for the creation of local variants of dictionary items that remain at agencies. When agency and federal dictionary items conflict, the federal dashboard-provided information is authoritative.

2.12 CyHy "Findings" Datasets

The Attack Surface Evaluation (ASE) team within DHS offers the Cyber Hygiene (CyHy): Vulnerability Scanning service to help federal agencies secure their internet/externally facing systems from "weak configuration and known vulnerabilities."[11] Agencies subscribe to this service by coordinating and registering an agency's known public IP space with the ASE team, after which automated scanning occurs on a recurring basis. The results are collated for analysis, and any confirmed findings are shared with agencies.

In coordination with the ASE team, the CDM program is developing an updated data dissemination approach that will allow the CDM system to pull and distribute these findings to facilitate automated, rapid sharing of cyber-relevant information to CDM practitioners. The information will be parsed, allocated, and stored in the CDM solution, where it can be visualized in context of other germane information provided by the CDM tools/sensors, which actively scan the interior of each agency's IT architecture. This cohesive approach will enrich the cyber awareness of agency stakeholders, allowing them to view risk as a measure of both internal and external defects.

[11] For more information, see the Cyber Hygiene Services website: https://www.cisa.gov/cyber-hygiene-services.

The CyHy dataset is awaiting further revision. This will be addressed in the near future.

2.13 ASM Datasets

In response to DHS Binding Operation Directive (BOD) 23-02: *Mitigating the Risk from Internet-Exposed Management Interfaces*, the ASE team runs tools weekly to discover and mitigate vulnerabilities across the attack surface. These tools develop and publish Attack Surface Management (ASM) Network Management Interface (NMI) data. NMI reports are the raw records CDM will ingest and provide to the agencies. The records themselves are what is used to create the BOD 23-02 metrics/visualizations.

Similar to CyHy Findings data, the CDM program is developing an updated data dissemination approach that will allow the CDM system to pull and distribute the ASM data to facilitate automated, rapid sharing of cyber-relevant information to CDM practitioners.

2.14 SCuBA Datasets

In response to malicious threat actors increasingly targeting cloud environments with evolving tactics to gain cloud access, CISA initiated the Secure Cloud Business Applications (SCuBA) project. BOD 25-01 requires agencies to implement requirements for SCuBA.

CISA provides SCuBA baselines to secure agency cloud business application environments. The SCuBA team developed ScubaGear for Microsoft 365 (M365) and ScubaGoggles for Google Workspace (GWS) to conduct scans for agencies and include SCuBA data to CDM, providing visibility to the agencies and CISA.

Similar to CyHy Findings data, the CDM program is developing an updated data dissemination approach that will allow the CDM system to pull and distribute the SCuBA data to facilitate automated, rapid sharing of cyber-relevant information to CDM practitioners.

2.15 VDP Datasets

In response to DHS BOD 20-01, which is to develop and publish Vulnerability Disclosure Policy (VDP) data, CDM is interested in accessing this data. VDP Policy is a formal policy that describes the activities that can be undertaken to find and report vulnerabilities in a legally authorized manner. CISA provides Bugcrowd to fulfill reporting requirements for this BOD.

Similar to CyHy Findings data, the CDM program is developing an updated data dissemination approach that will allow the CDM system to pull and distribute the VDP data to facilitate automated, rapid sharing of cyber-relevant information to CDM practitioners.

2.16 Threat Intelligence Within CDM

One of the CDM's core objectives is to provide stakeholders with information that helps them identify and prioritize the worst issues on their network. In full support of this vision and to evolve the CDM system to be a consummate platform for risk management practitioners, the CDM Data Model has incorporated threat intelligence products and correlated them to defects that can greatly benefit from this external information. Similar to other referential contracts that are containers for CDM-disseminated information (e.g., CVE dictionaries), the LDM implemented an entity, **ThreatIntelligence**, that can accommodate vendor/organization-agnostic threat intelligence to elevate the understanding of risk of any defect that the CDM system may discover within an agency's network.

2.17 CDM-Required Data

This document specifies the data elements that are *required*, *conditionally required*, and *recommended*.

Required data elements are identified as "required" because they fulfill certain CDM mission-essential data needs.[12] Specifically, they represent data that feeds CDM data requirements (e.g., interrogation actions indicating CDM PMO-prescribed data needs). Interrogation actions are a set of mechanisms that enable users to interrogate the information collected by CDM in a meaningful way.

Conditionally required data elements are identified as "conditionally required" because they are required if a certain condition exists. They carry the same related guidance as "required" (i.e., CDM mission-essential datasets) but do not unilaterally apply without some additional context. This additional context includes the following:

- **CDM capability required for production** – Some agencies may not have access to the security capabilities needed to produce this data. Therefore, the data may be required only for CDM solutions that use that capability (e.g., NAC, EMM).
- **Context of CDM object** – Some attribute-level data requirements apply only when a specific device or user type is present in the solution, or when related attributes or entities exist.

For all data elements tagged as "conditionally required," the CDM PMO will state the condition that applies.

Recommended data elements are identified as important but do not necessarily directly satisfy essential data needs. These may be data attributes that support the required (or conditionally required) data by providing operational context or other information to assist agency decision-makers. These are recommended data elements that are included in the LDM or come from other sources (e.g., industry) and can enhance an agency dashboard use case. The CDM PMO considers these optional but strongly recommended when achievable. *All data elements that are not required or conditionally required are recommended*.

3 DATA MODEL KEY TERMS

CDM Data Model key terms provide additional context for reference when interpreting the logical and conceptual data models and their associated entities and attributes.

Actual State – The discoverable/observable state of relevant objects (e.g., devices, software) based on security-related, sensor-collected information. The actual state includes the states and/or behaviors that may indicate the presence of a security defect. [CDM Technical Capabilities, Vol. 1] [CDM PMO]

Approved Software – Software products collated from an agency-defined approved software list that has been developed and validated, subject to policy. Software does not have to be installed or present on an agency's network to be on the approved software list. Approved software lists may be documented through a combination of system security plans (SSPs), proper enterprise architectural governance policies by an agency or organizational unit (e.g., an approved enterprise architecture and relevant technical insertions at an agency may be automatically authorized to all subordinate OUs and their FISMA systems, and thus would be part of an approved software list that pertains to these structures), and/or by virtue of individual device-based dispensations. Approved software lists are considered part of "desired state" policies that are used by the CDM system to determine if/when authorized/unauthorized software exists.

Attack Surface Management Network Management Interface – Attack surface management (ASM) is the process of continuously identifying, monitoring, and managing all internal and external internet-connected assets for potential attack vectors and exposures. Network management interface (NMI) reports are the raw records the dashboard will ingest and provide to the agencies. [CDM PMO]

[12] Note that when required data is discussed in this document, it does not include that dimension of physical implementation where additional data fields may be required to ensure dashboard functionality as designed.

"Authorized" Device – A device is considered authorized—by CDM and as it relates to this data model—if it belongs to a FISMA system boundary (i.e., information system, FISMA containers; see **SystemBoundary** for more information) that has a current, valid ATO. FISMA system boundaries are authorized by an authorizing official who provides an authorization decision and formally assumes responsibility for operating an information system at an acceptable level of risk. Devices not associated to authorized system boundaries are considered "unauthorized." Agency policies determine when/if associations to any SystemBoundary are made and may be implemented in CDM tools/sensors directly. [CDM PMO]

"Authorized" Software – Installed software is considered authorized if it is on the agency's approved software list that is associated with the device. (See **SoftwareAuthorizationStatus** in the Data Dictionary for the Logical Data Model section.) [CDM PMO]

Authorization Decision – An action related to authorizing a system for a prescribed level of operation by an authorizing official. (See **AuthorizationDecision** in the Data Dictionary for the Logical Data Model section.) [CDM PMO]

Authorizing Official – A senior federal official or executive with the authority to authorize (i.e., assume responsibility for) the operation of an information system or the use of a designated set of common controls at an acceptable level of risk to agency operations (including mission, functions, image, or reputation), agency assets, individuals, other organizations, and the nation. [NIST SP 800-53 Revision 5, 800-53A Revision 5, and 800-37 Revision 2] (See **AuthorizingOfficial** in the Data Dictionary for the Logical Data Model section.) [CDM PMO]

Benchmark – A set of federal security configuration settings that may be used in developing a standardized set of configuration requirements for agency IT systems. Available standard industry benchmarks include:

- United States Government Configuration Baseline (USGCB)
- DISA Secure Technical Implementation Guides (STIGs)
- Center for Internet Security Benchmarks (CIS Benchmarks)

[CDM PMO]

Certificates – A set of data that uniquely identifies an entity, contains the entity's public key and possibly other information, and is digitally signed by a trusted party, thereby binding the public key to the entity. Additional information in the certificate could specify how the key is used and its validity period. [NIST Special Publication 800-57 Part 1, Revision 5]

Common Vulnerabilities and Exposures (CVEs) – An individual record from a dictionary of publicly known information security vulnerabilities and exposures. It includes a standard for information security vulnerability names. The standard allows data exchange between security products. CVEs are used to populate CDM vulnerable software data. (See **CVEID, CVEType, CVEDescription, CVEReferences,** et al. in the Data Dictionary for the Logical Data Model section.) [CVE.org]

Credential – Evidence attesting to one's right to credit or authority. In the NIST Standard, it is the personal identity verification (PIV) card or derived PIV credential associated with an individual that authoritatively binds an identity (and, optionally, additional attributes) to that individual. [NIST FIPS 201-3]

Critical Software – Software that has direct software dependencies upon one or more components with at least one of the following attributes:

- Is designed to run with elevated privilege or manage privileges
- Has direct or privileged access to networking or computing resources

- Is designed to control access to data or OT
- Performs a function critical to trust
- Operates outside of normal trust boundaries with privileged access[13]

This definition applies to software of all forms (e.g., standalone software, software integral to specific devices or hardware components, cloud-based software) purchased for, or deployed in, production systems and used for operational purposes.

CVE Dictionary – Provided as GFI to CDM solutions and used to baseline key standardizations that the CDM program will leverage to identify security risk. For CVEs, this includes looking at a comprehensive list of vulnerabilities as codified by the NVD. This element will serve as a referential data item, for which supplementation information about a CVE will be present. (See **CVEDictionary** in the Data Dictionary for the Logical Data Model section.)

CyHy Finding – A cybersecurity-relevant weakness or vulnerability that has been discovered by the external scanning activities executed by the ASE team. CyHy findings span different types of "defects" as defined by the CDM program and, on a case-by-case basis, may be indicative of a misconfiguration or vulnerability on network, the latter of which will have a normalized CVE ID assigned to it. Each CyHy finding has calculated values (in days) associated with its age to facilitate BOD compliance. [CyHy]

Data Interrogation Action – Data interrogation actions are a set of mechanisms that enable users to interrogate the information collected by CDM. The desired behavior of data interrogation actions is that they can be specified such that CDM can execute them directly on CDM data without having to modify the CDM implementation. They shall be specified such that an inconsistent result due to an action being interpreted differently by each instance of CDM does not occur. [CDM PMO]

Denied Software – Denied software are software products that may be collated from an agency-defined denied software list that has been developed and validated, subject to policy. Denied software lists may be documented through a combination of SSPs, proper enterprise architectural governance policies by each agency or organizational unit (e.g., an approved EA and relevant technical insertions at an agency may be automatically authorized to all subordinate OUs and their FISMA systems), or by virtue of device-based dispensations. Enforcement of and compliance with denied software lists are considered part of desired state policies that are used by the CDM system to determine if/when authorized/unauthorized software exists.

Derived PIV Credential – A credential issued based on proof of possession and control of a PIV card. Derived PIV credentials are typically used in situations that do not easily accommodate a PIV card, such as in conjunction with mobile devices. [NIST FIPS 201-3]

Desired State – A defined value, list, or rule (specification) that details or enables the derivation of the state desired by an organization to reduce its information security risk. Desired state specifications are generally derived from policy and provided within interrogation specifications. [CDM PMO]

Device On Network – A physical and/or virtual hardware asset managed, inventoried, or otherwise detected by the CDM solution. For CDM Asset Management capability, in-scope IT assets are "IP addressable" over an agency's network. To be included in the CDM implementation, these assets are also positively adjudicated as "in scope" within appropriate agency enclaves by the CDM PMO. The **DeviceOnNetwork** entity is modeled as a generalization (superclass) with specialization (subclass) entities of **ToolSensorDeviceOnNetwork** and

[13] "Critical Software – Definition & Explanatory Material," Executive Order 14028, Improving the Nation's Cybersecurity, last modified July 9, 2021. https://www.nist.gov/itl/executive-order-improving-nations-cybersecurity/critical-software-definition-explanatory.

MobileDeviceOnNetwork. (See **DeviceOnNetwork** in the Data Dictionary for the Logical Data Model section.) [CDM Technical Capabilities, Vol. 2] [CDM PMO]

(***Note:*** *This model is based on the policy that each device discovered belongs to a single documented FISMA system/boundary, as stipulated by NIST special publications.)*

Device Types – Some device subtypes descriptions can be used to typecast devices to traditionally understood groupings.

Digital Worker – An automated, software-based tool, application, or agent that performs a business task or process similar to a human user and uses artificial intelligence (AI) or other autonomous decision-making capabilities. [Digital Worker Identity Playbook (idmanagement.gov)]

Endpoint Types (Operational Technology Subtypes) – An introduction of endpoint operational technology (OT) subtype descriptions for clarification and disambiguation.

- **OT Engineering Workstation (e.g., OT-Specific Software)** – Engineering workstations are devices used by human operators or engineers to perform various configuration, programming, maintenance, diagnostic, and operational tasks. Workstations typically utilize standard desktop or laptop hardware and operating systems (e.g., MS Windows) but run dedicated control system applications or diagnostic/management software to support interfacing with the control servers or field devices. [MITRE ATTC&K] [CDM PMO]
- **OT Control Server (e.g., supervisory control and data acquisition [SCADA], DMS, and EMS)** – Control servers are typically a software platform that runs on a modern server operating system (e.g., MS Windows Server). The server typically uses one or more automation protocols (e.g., Modbus, DNP3) to communicate with the various low-level control devices such as remote terminal units (RTUs) and programmable logic controllers (PLCs). The control server also provides an interface/network service to connect with a human-machine interface (HMI). [MITRE ATTC&K] [CDM PMO]

  OT Data Historian (e.g., OT-Specific Software or Traditional Database) – Data historians, or historians, are systems used to collect and store data, including telemetry, events, alerts, and alarms about the operational process and supporting devices. The historian typically utilizes a database to store the collected data and commonly provides tools and interfaces to support the analysis of the data. Data historians are often used to support various engineering or business analysis functions, and therefore commonly need access from the corporate network. [MITRE ATTC&K] [CDM PMO]

  OT HMI on IT (e.g., OT Specific Vendor Software) – Customizable software graphical user interface application running on a standard operating system used by an operator to monitor the real-time status of an operational process and to perform necessary control functions, including the adjustment of device parameters. [CDM PMO]

Enterprise Internet of Things Types – An introduction of enterprise Internet of Things (IoT) subtype descriptions for clarification and disambiguation.

- **Ground Response Robot (e.g., wheeled, tracked, legged, other)** – A remotely deployed and controlled device on the ground intended to perform operational tasks at operational tempos, often in hazardous or inaccessible environments. [CDM PMO]

Ephemeral Asset – An ephemeral asset is an asset such as a container or a third-party-managed software as a service (SaaS) solution. [BOD 23-01]

Event [On Network] – Any observable occurrence in a system or network [NIST 800-61]. A discovered event can be informational, such as documenting a successful authentication event on a web server (e.g., "User John

logged into WebAcme.Org"), and logging data captured such as in Microsoft Sysmon logging, or adverse in nature (e.g., "System SQL.corp.net unreachable for 60 seconds"), depending on the context of the tools and what they are configured to detect and report on. What distinguishes the deluge of events that are triggered and captured directly by tools/sensors from the events that are correlated and curated for use in the CDM system (i.e., inventoried in this data model as **EventOnNetwork**) is the actual analysis/synthesis of the original event from raw data to "relevant" information—information indicating activity in the network that presents risk to information systems and requires attention. The transformation of raw data into relevant information is largely encapsulated into two sources (1) CDM processes and (2) agency policies. CDM processes are indicative of pre-established capabilities and the established reporting structure conveyed in this model—for example, the requirement to report negatively adjudicated NAC events in the solution. Agency policies generically describe mature processes and technologies that facilitate, in a manual or automated fashion, the transformation of any set of events into risk information—for example, determination of malicious activities by correlation of firewall events to malware indicators. Agency technologies and supporting processes, which may be provided by capabilities baselined within CDM, will generally improve the proactive identification of risk-relevant events and may include investments in areas such as the following:

- Intrusion detection/prevention systems
- Threat intelligence/automated indicator sharing systems
- Machine-learning (ML)/AI-based applications (within or external to tools)
- Security information and event management solutions (SIEM)[14]

Technologies should be customized to reflect tools and sensors that are most closely aligned to agencies' policies and procedures for incident detection and management based upon their own thresholds (e.g., clipping levels, "accuracy" of an alert, source(s) of alerts, etc.).

Events are inventoried within the CDM architecture only in relation to facilitating the identification and reporting of confirmed or suspected IT-based security incidents.

In the LDM, events are captured in the **EventOnNetwork** entity and modeled as a generalization (superclass) with specialization (subclass) entities that relate to the various types of CDM-recognized events and the distinctiveness of their data. For example, **NACEventOnNetwork** and **MaliciousEventOnNetwork** are type casted for NAC, SWAM, and incident response-related CDM capabilities, respectively. [CDM Technical Capabilities, Vol. 2]

Facility – For the purposes of the CDM program, facilities are any physical space (site, campus, building, etc.) that can be documented to facilitate the assignment of geographical information for agency personnel or FISMA system components (e.g., devices, software, etc.) for physical asset accountability. Facilities can be official duty stations, datacenters, or some combination of both. In the CDM Data Model, facilities may also be interrelated, such that a larger facility holds and is related to a more specific locale that is more informational for documenting an asset's physical location (e.g., a server room or datacenter inside an agency's campus location). When the physical location of assets is fluid, as is the case with cloud services, provider-related information (e.g., company name, specific information on hosting agreements) may be provided. Facilities may be agency owned/operated or provided as a service through a hosting agreement. Under CDM, all colocation, contractor owned/operated, and cloud hosting providers* should be documented if they are relevant to people or devices covered by CDM.

**Note:* In many circumstances under shared services (e.g., cloud providers), it might not be realistic to

[14] For a comprehensive listing, please refer to the program's baseline of requirements for CDM capabilities.

document actual geographical location. In these scenarios, it is critical to capture not the physical location, such as an address, but rather the organizational information of the hosting company and any related geographic information on the location of the hosting center, which may vary by vendor. For example, "AWS GovCloud™," "US-EAST Region" would be an appropriate moniker for virtual servers that are hosted by AWS on behalf of an agency.

FIPS 199 Impact Components – The generalized format for expressing the security category (SC) of an information system (IS): SC information system = [(confidentiality, impact), (integrity, impact), (availability, impact)]. (See **ImpactLevel** in the Data Dictionary for the Logical Data Model section.) [FIPS Pub 199, 44 U.S.C., SEC. 3542] [CDM PMO]

- **Availability** – The applicable FIPS 199 impact level used to indicate timeliness, reliability of access, and use of information within a FISMA system.
- **Confidentiality** – The applicable FIPS 199 impact level used to indicate the appropriate level of rigor to preserve authorized restrictions on information access and disclosure, including the means for protecting personal privacy and propriety information.
- **Integrity** – The applicable FIPS 199 impact level used to indicate protection necessary to guard against improper information modification or destruction, including ensuring information non-repudiation and authenticity.

Healthcare IoT – IoT exclusive to the healthcare industry. Healthcare IoT includes IP-addressable devices such as infusion pumps and diagnostic machines. [CDM PMO]

Incident [On Network] – Incidents are formally defined by NIST as "a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices…," [NIST 800-61]. The CDM architecture follows this guidance and requires agencies to codify any "cyber"[15] incident that is suspected or confirmed within the boundary of an agency's network. The enumeration of the context of each incident is driven by associated attributes derived from federal guidance (i.e., CISA Federal Incident Notification Guidelines, NIST 800-61r2) and further enriched with strategic information sourced from other industry standards, such as Veris, Malware Attribute Enumeration and Characterization (MAEC)™, Common Attack Pattern Enumerations and Classifications (CAPEC)™, and others. Incidents are typically populated from data that is sourced from correlated events (**EventOnNetwork**). This data can indicate network activity that may be unauthorized, malicious, or otherwise in violation of explicit IT policy. Correlated events may be facilitated by automation or manual attribution to incidents, but, when possible, should be associated and reported as part of the detailed contextual information of each incident. The CDM architecture is primarily focused on documenting incidents from a strategic perspective, including leveraging the necessary entities and attributes to satisfy all federal requirements relating to reporting to DHS and other federal oversight bodies. [CDM Technical Capabilities, Vol. 2]

Industrial Control Systems (ICSs) – A general term that encompasses several types of control systems, including SCADA systems, distributed control systems (DCSs), and other control system configurations, such as programmable logic controllers (PLCs) often found in industrial sectors and critical infrastructures. An ICS consists of combinations of control components (e.g., electrical, mechanical, hydraulic, pneumatic) that act together to achieve an industrial objective (e.g., manufacturing, transportation of matter or energy). For this document, ICS is equivalent to Operational Technology (OT).

[15] The CDM program currently as scoped includes reportable incidents that are only "cybersecurity related." This includes incidents that are germane to computer systems and networks as generally attributable to human-caused threats (e.g., malicious actors, human errors) and not natural disasters, power failures, etc.

Enterprise IoT – User or industrial devices that are connected to the internet. IoT devices include sensors, controllers, and household appliances. IoT devices have at least one transducer (sensor or actuator) for interacting directly with the physical world and at least one network interface (e.g., ethernet, Wi-Fi, Bluetooth) for interfacing with the digital world. The IoT devices and related definitions have evolved over time, originally including non-industrial devices, but now seemingly including industrial OT devices that are connected to the Internet (IoT) as well. This class of IoT is referred to as "ENTERPRISE" IoT.

Interrogation Specification – A specification that can be automated in some way and is in a formal language that describes how a data interrogation action should interact with the CDM data. It produces datasets that fulfill a fundamental data request with a consistent result for the CDM program (e.g., discover unauthorized assets). Interrogation specifications are derived from various cybersecurity-relevant artifacts including, but not limited to, CDM program requirements, common federal yearly reported metrics (i.e., FISMA metrics), NIST publications, and other federal requirements (e.g., FIPS). See Appendix B for more information. [CDM PMO]

Known Exploited Vulnerabilities (KEVs) – For the benefit of the cybersecurity community and network defenders—and to help every organization better manage vulnerabilities and keep pace with threat activity—CISA maintains the Known Exploited Vulnerability (KEV) catalog, the authoritative source for vulnerabilities that have been exploited in the wild. CISA strongly recommends all organizations review and monitor the KEV catalog and prioritize remediation of listed vulnerabilities to reduce the likelihood of compromise by known threat actors.

"Managed" Application: A managed application is a construct within the CDM solution that allows for the separation of accountability between specific installed software (e.g., actively managed applications) and other aspects of the supporting device or infrastructure to provide more granular risk tracking and reporting. Analogous to a type of information system "component" as defined by the NIST RMF, managed applications support the need to implement "split responsibilities" between software and their devices (or supporting infrastructure) when deemed appropriate by an agency. In the CDM LDM, this functionality is achieved by creating a logical entity (**ManagedAppOnNetwork**) that captures discrete instances of installed software detected on devices under a common namespace to facilitate unique identification and subsequent risk assignment. The specifications for each managed application are constructed and inventoried based on agency governance and policy. The **ManagedAppOnNetwork** entity has the same organizational and system boundary traceability requirements as a traditional device in the CDM LDM. [CDM PMO]

"Managed" Device – A device is considered managed within the CDM solution if it satisfies both of the following conditions:

- Has an identified information system owner for the associated system boundary of the device
- Has an assigned OU tag (i.e., assigned to an OU container, facilitating GFE status)

Agency policy dictates how devices are associated with information system boundaries, and this association will indirectly allow information system owner assignments, presumed to be one-to-many, to devices to occur. Assigning responsible and accountable parties to devices is one of the fundamental needs for addressing security deficiencies and helps ensure proper oversight and governance. The information "system owner is an organizational official responsible for the procurement, development, integration, modification, operation, maintenance, and disposal of a system."[16] Any device that does not have this key party assigned (including lack of an OU boundary assignment) is considered "unmanaged." (See **OrganizationalUnitBoundary** and **SystemBoundary** in the Data Dictionary for the Logical Data Model section for further clarification.) [CDM PMO]

[16] NIST, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Risk for Security and Privacy," NIST SP 800-37r2, December 2018, https://csrc.nist.gov/pubs/sp/800/37/r2/final.

Misconfiguration – A configuration that is discovered, through interrogation of a device, to be in violation of the expected value(s) for that configuration. [CDM PMO]

Multifactor Authentication (MFA) – An authentication process that requires multiple response inputs drawing on a variety of personal factors, namely:

- Something you know (e.g., personal identification number [PIN] or password)
- Something you have (e.g., PIV card or token)
- Something you are (e.g., biometrics)

For CDM Data Model context, MFA is critical in providing levels of assurance for account authentication (and associated privileges) and is germane for credential management, as proper Identity Assurance Level (IAL)/Authenticator Assurance Level (AAL) credentials are commonly used to meet MFA requirements. [CDM PMO]

Network Access Protection [Network Access Control (NAC)] – Network access protection is the formal name of the technical capability that falls within the BOUND-F suite of network-based controls. In the context of this document, the terms network access control (NAC) and network access protection are equivalent. They relate to a capability that ensures a device is allowed/permitted to connect and access resources on an enterprise network only if that device is "compliant" or satisfies some set of agency policies that are implemented in a CDM tool/sensor (i.e., NAC tool) that is actively performing validation against those policies. Examples of these policies include updated software patches being installed, antivirus signatures being up to date, nonexistence of certain vulnerabilities, etc. The NAC tool may take proactive measures (BLOCK or QUARANTINE) predicated on a device's compliance. [CDM Technical Capabilities, Vol. 2]

Network Account – An account that provides access to an agency's network and information system(s). A network account is characterized by an enterprise centralized account management system that mediates authentication and authorization activities. Examples are Kerberos for Microsoft's Active Directory-centric networks or RADIUS protocol on other centrally authenticated networks. [CDM PMO]

(***Note:*** *"Network Account" is not necessarily inclusive of the large variety of accounts that operate within the boundaries of a given network and might be under control of a single sign-on solution*.)

NIST Security Control [Security control] – The safeguards or countermeasures prescribed for an information system or an organization to protect the confidentiality, integrity, and availability of the system and its information. [NIST 800-53 r5]

OT Types – An introduction of OT subtype descriptions for clarification and disambiguation.

- **Controller (e.g., PLC, RTU, Intelligent Electronic Device [IED], Safety Controller)** – A controller will typically be embedded OT technology like a PLC, IED, RTU, or safety device. [MITRE ATTC&K] [CDM PMO]
- **Embedded HMI** – An HMI is a user interface or dashboard that connects a person to a machine, system or device. HMIs are systems used by an operator to monitor the real-time status of an operational process and to perform necessary control functions, including the adjustment of device parameters. HMI can take various forms. An embedded HMI is a dedicated screen or control panel integrated with a specific device/controller that interfaces with a control/SCADA server. [MITRE ATTC&K] [CDM PMO]

Organizational Unit (OU) – An entity of any size, complexity, or positioning within an organizational structure (e.g., a federal agency or any of its operational subcomponents, such as an operational division or bureau).

(See **OrganizationalUnitBoundary** in the Data Dictionary for the Logical Data Model section.) [NIST SP 800-53 Revision 5; SP 800-53A Revision 5; SP 800-37 Revision 2] [CDM PMO]

Personal Identity Verification (PIV) – Physical artifact (e.g., identity card, smart card) issued to an individual that contains stored identity credentials (e.g., photograph, cryptographic keys, digitized fingerprint representation) such that a claimed identity of the cardholder may be verified against the stored credentials by another person (human-readable and verifiable) or an automated process (computer-readable and verifiable). The federal standard for this is specified as FIPS 201. [FY 2021 CIO FISMA Metrics]

Relying Party (RP) (aka Service Provider [SP]) – An entity that relies upon the subscriber's authenticator(s) and credentials, or a verifier's assertion of a claimant's identity, typically to process a transaction or grant access to information or a system. (NIST SP 800-63 Revision 4)

Response Activity – Various stages and activities are included in the incident response lifecycle, including the following:

- Detection and analysis
- Containment
- Eradication
- Post-incident activities (e.g., lessons learned)

To facilitate holistic reporting under CDM, agencies are asked to detail, to the fullest extent possible, these activities using the related data attributes under the **ResponseActivity** entity. The model also requires associating agency resources who would serve as lead personnel in either an execution, oversight, and/or accountability role in relation to these activities. Ideally, a collection of well-documented response activities can be used to construct a cradle-to-grave timeline of agency actions in response to a specific incident on an agency's network. [NIST 800-61r2]

Secure Cloud Business Applications (SCuBA) External Data – CISA provides SCuBA baselines to secure agency cloud business application environments. Agencies download SCuBA tools and perform assessments, but this does not give CISA visibility into an agency's risk posture. Including SCuBA data in CDM gives visibility to agencies and CISA. [CDM PMO]

System [FISMA System, FISMA Container] – A boundary including all components of an information system to be authorized for operation by an authorizing official, excluding separately authorized systems, to which the information system is connected. A System may include one or multiple **subsystems**, where there is a need to divide complex systems into a set of manageable system elements or identify those elements that support a similar mission but are sufficiently distinct to be identified separately.[17] A System is also commonly referred to as a FISMA System. (See **SystemBoundary** and **SystemBoundaryID** in the Data Dictionary for the Logical Data Model section.) [Committee on National Security Systems Instruction No.4009; NIST SP 800-53 Revision 5; SP 800-53A Revision 5; SP 800-37 Revision 2] [CDM PMO]

System Interconnection – A direct connection between two or more systems in different authorization boundaries for the purpose of exchanging information and/or allowing access to information, information services, and resources. For this document, the term "system boundary" is employed equivalently with "authorization boundary." ***Note:*** *There are no prescribed values for system interconnections—it may be open text field—other than the FIPS-199 high watermark values prescribed above. The data is sourced from the*

[17] NIST, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Risk for Security and Privacy," NIST SP 800-37r2, December 2018, https://csrc.nist.gov/pubs/sp/800/37/r2/final.

System Integrator (SI) (presumed to be from governance, risk, and compliance tool integration at layer B.)

Unique Software – An inventory item that represents a formally named software product, which is an abstract encapsulation of a unique application or codebase found on an agency's network that can actively run (i.e., access/utilize memory space, create central processing unit [CPU] tasks/threads) on an IT hardware asset. A software product may be composed of multiple ancillary items, such as software component files (e.g., code libraries, dynamic-link libraries [DLLs], scripts, multiple .exe, .rar, .rpms). Unique software records can be discovered either from automated sensors (e.g., CDM-provided SWAM tools) or from other authoritative software inventory sources providing relevant information about software that exists within an agency's boundary (e.g., logistics database, configuration management databases, license management software systems). (See **UniqueSoftware** in the Data Dictionary for the Logical Data Model section.) [CDM Technical Capabilities, Vol. 2] [CDM PMO]

Unique Identifiers (UIDs) [*EntityName*ID] – Identifiers (also interpreted as primary keys and index values) that enable a record, entity, or other inventoried item to be singled out by referencing the UID value in a query or search. In the CDM Data Model, various entities leverage the UID concept and the implied requirement to be uniquely identifiable by a referential attribute (e.g., The **SystemBoundaryID** attribute shall uniquely identify a FISMA system). [CDM PMO]

4 DATA DICTIONARY FOR THE LOGICAL DATA MODEL

This section contains the attributes and entities within the CDM LDM provided as GFI to CDM stakeholders. It is intended to clarify the information requirements of each attribute, as called out by the model. Note that all data is implicitly expected to be provided by the CDM solution unless otherwise specified. If data is optional or not available, the CDM solution can produce a default representation of a NULL or EMPTY value as appropriate. However, in cases where the data attribute is required, a NULL value may constitute a defect (i.e., unassigned values for required attributes that are necessary for evaluating an expression will be considered a potential defect). Principal source materials used in derivation of these entities and attributes are noted in brackets (e.g., [CDM PMO] indicates that mission requirements and/or derived needs are principally used in producing this data element). **As noted in Section 2.15, all data elements that are not required or conditionally required are recommended.**

ASMNMIAlert – An entity that records data from reports on the status of Federal Civilian Executive Branch compliance reporting for BOD 23-02. [CDM PMO] [Required]

- **ASMNMIAlertBusinessUnits** – An attribute that captures the business units assigned to the assets associated with the alert. [CDM PMO]
- **ASMNMIAlertDescription** – An attribute that captures a text summary of an event, including the alert source, alert name, severity, and file path. [CDM PMO]
- **ASMNMIAlertDeviceIPv4Addresses** – An attribute that captures a list of IPv4 addresses associated with this asset. [CDM PMO]
- **ASMNMIAlertDeviceIPv6Addresses** – An attribute that captures a list of IPv6 addresses associated with this asset. [CDM PMO]
- **ASMNMIAlertDomainNames** – An attribute that captures the domain names on which an alert was triggered. [CDM PMO]
- **ASMNMIAlertID** – An attribute that captures a unique identifier for an alert. [CDM PMO] [REQUIRED]
- **ASMNMIAlertRemediationGuidance** – An attribute that captures guidance on how to remediate the alert. [CDM PMO]
- **ASMNMIAlertSeverity** – An attribute that captures the severity that was assigned to the alert when it was triggered (Low, Medium, High, or Critical). [CDM PMO] [REQUIRED]
- **ASMNMIAlertStatus** – An attribute that captures the finding status assigned manually by the directives team. Valid values must be one and only one of the following:
  - OPEN
  - CLOSED – AGENCY ADDRESSED
  - CLOSED – DISAPPEARED FROM SCANS
  - OUT-OF-SCOPE
  - FALSE POSITIVE

  [CDM PMO]
- **ASMNMIAlertStatusNotes** – An attribute that captures notes associated with finding status. [CDM PMO]

Certificate – An entity that captures the associated information of a digital certificate, which minimally includes (1) identifying the certification authority issuing it, (2) naming or identifying its subscriber, (3) including the subscriber's public key, (4) identifying its operational period, and (5) including whether it is digitally signed by the certification authority issuing it. [NIST SP 800-32] [CONDITIONALLY REQUIRED] ***Note:*** *"Conditionally required" because some agencies may not have access to the* ***Certificate Management*** *security capabilities* ***[BOUND-E]*** *necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ* ***Certificate Management****.)*

CertificateCA – An attribute that captures the name of the certificate authority (CA). The CA confirms the identities of parties sending or receiving the electronic communications. [NIST SP 800-32] [CONDITIONALLY REQUIRED] (***Note:*** *See above for explanation of "conditionally required.")*

CertificateCreatedDate – An attribute that captures the date of certificate creation. [CDM PMO]

CertificateDescription – An attribute that captures mission/operational usage information (e.g., "supports TLS for ABOE.gov," "supports mission system XYZ"). [CDM PMO]

CertificateDistinguishedName – An attribute that captures a sequence of relative distinguished names (RDNs) of the entry, which represents the object and those of all of its superior entries (in descending order). Each RDN is a set of one or more attribute type and value pairs expressed as a type/value pair. [CDM PMO and ITU-T Rec-X.501-2016]

CertificateExtendedKeyUsage – An attribute that captures the information relating to one or more purposes for which the certified public key may be used, in addition to, or in place of, the basic purposes indicated in the key usage extension. In general, this extension will appear only in end entity certificates (e.g., "Server Authentication" OID 1.3.6.1.5.5.7.3.1). [RFC 5280]

CertificateFQDN – An attribute that captures the fully qualified domain name of a certificate, if applicable. A FQDN is a domain name that includes the labels of all superior nodes in the internet Domain Name System (DNS). [CDM PMO]

CertificateID – An attribute that captures a unique identifier for a certificate. For instance, this could be based on the serial number and issuer name fields. [CDM PMO] [CONDITIONALLY REQUIRED] (***Note:*** *See above for explanation of "conditionally required.")*

CertificateIssuer – An attribute that captures the name of the certificate issuer or "SELF-SIGNED" value. The issuer is the distinguished name of the trusted third party that generated the certificate. [CDM PMO, NIST SP 800-32]

CertificateKeyUsage – An attribute that captures the set of generic uses for the key. For users or systems, the key may be used for digital signatures on documents, authentication, key management, or data encipherment. For CAs, the key may be used for verifying signatures on certificates or certificate revocation lists (CRLs). This field can be extracted from the X.509 Key Usage certificate extension field. This attribute may have one or more of the following values:

- DIGITALSIGNATURE
- NONREPUDIATION
- KEYENCIPHERMENT
- DATAENCIPHERMENT
- KEYAGREEMENT

- KEYCERTSIGN
- CRLSIGN
- ENCIPHERONLY
- DECIPHERONLY

[NIST SP 800-32]

CertificateLastReportingDate – An attribute that captures the date of the last (most recent) certificate check. [CDM PMO]

CertificatePublicKeySize – An attribute that captures the size (in bits) of the certificate public key. [CDM PMO]

CertificateRiskStatus – An attribute that captures a Boolean value that indicates whether one or more certificate defects have been detected for the inventoried certificate that may put an agency's infrastructure at risk. [CDM PMO]

CertificateSignatureAlgorithm – An attribute that captures the algorithm used to sign the content using the private key. [CDM PMO]

CertificateSignatureHashAlgorithm – An attribute that captures the algorithm used to hash the certificate content before signing; this is used in certificate path construction. [CDM PMO]

CertificateSubject – An attribute that captures the "subject" field of the certificate, which details the entity named in the certificate. [CDM PMO, NIST SP 800-32]

CertificateSubjectAlternateName – An attribute that captures the subject alternative name for a certificate. The subject alternative name extension is used to provide other name forms for the owner of the private key, such as DNS names or email addresses. [NIST SP 800-32]

CertificateSubjectCommonName – An attribute that captures a certificate's subject common name; this is typically composed of host plus domain name (e.g., www.dhs.gov). [CDM PMO]

CertificateValidFromDate – An attribute that captures the "Valid from" date of a certificate. [CDM PMO]

CertificateValidToDate – An attribute that captures the "Valid to" date of a certificate. [CDM PMO]

CertificateDefectCondition – An entity that represents a single discovered certificate-related defect that can be analyzed by the agency for risk determination. Certificate defects are based on certificate parameters not aligned with industry best practices and/or agency certificate polices (as found and reported by the certificate management tool/sensor) that need to be addressed. [CDM PMO]

CertificateDefectConditionID – An attribute that captures a unique identifier for a certificate defect condition, represented by the **CertificateDefectCondition** entity. [CDM PMO]

CertificateDefectDetail – An attribute that captures the certificate risk(s) (indicated by **CertificateRiskStatus**) into well-formed categories, including one or more of the following types of certificate risks:

- EXPIRING CERTIFICATES
- INVALID PERIOD
- EXPIRED PERIOD

- FAILED VALIDATION
- INVALID DOMAIN NAME
- UNAPPROVED ISSUER
- SELF-SIGNED CERTIFICATE
- UNAPPROVED SIGNING ALGORITHM
- UNAPPROVED HASHING ALGORITHM
- UNIQUE NAME VIOLATION
- WEAK PUBLIC KEY SIZE
- WEAK SIGNING ALGORITHM
- OTHER (as specified)

[CDM PMO]

CertificateDefectDiscoveryDate – An attribute that captures the date when the certificate defect was first discovered. [CDM PMO]

CertificateDefectException – A Boolean attribute that captures the existence of a defect exception, if applicable, to a related certificate defect. [CDM PMO]

CertificateDefectExceptionDescription – An attribute that captures the justification or rationale associated with an agency's exception(s) to detected certificate defect. [CDM PMO]

CVEDictionary – An entity that represents authoritative information for the CDM solution for a specific, referenced CVE. [CDM PMO] [REQUIRED] (***Note:*** *The vulnerabilities that will be required to be discovered, inventoried, and summarily reported to the federal dashboard will be disseminated as a set of* **CVEDictionary** *entities, along with each entity's respective attributes, through the dashboard-to-dashboard communication flow. For additional information, refer to the CVE section.*)

CVEDescription - An attribute that captures the general description of the vulnerability as specified by an external source, such as the NVD. [CDM PMO] [CDM PMO] [REQUIRED]***Sample Value:*** *"/usr/ucb/ps in Sun Microsystems Solaris 8 and 9, and certain earlier releases, allows local users to view the environment variables and values of arbitrary processes via the -e option."*

CVEDictionaryUpdateDate – An attribute that captures the date that the **CVEDictionary** data entry was last updated. [CDM PMO] [REQUIRED]

CVEID – An attribute that captures a universally unique identifier assigned to a specific vulnerability, as defined by its relevant CVE (i.e., Assigned CVE Identification), which is associated with a discovered vulnerability in software that is present within the inventory of an agency. (See **CVE** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

CVEPublishedDate – An attribute that captures the original date the CVE dictionary entry was codified or published. [CDM PMO] [REQUIRED]

CVEReferences – An attribute that captures any external uniform resource locators (URLs)/uniform resource identifiers (URIs) that add more contextual information around the CVE, such as reference links to a software manufacturer's website or a security bulletin. [CDM PMO]

CVEStatus – An attribute that captures that a CVE has been marked "REJECT," "RESERVED." or

"PUBLISHED" in the CVE list as identified in the NVD. [CDM PMO]

CVEScore – An attribute that captures the scoring parameter as determined by the CDM program and provided by the CVE dictionary (i.e., CVSS Score v2 and/or v3). [CDM PMO] [CONDITIONALLY REQUIRED] (***Note:*** *"Conditionally required" because NVD may maintain some CVEs with no scores; otherwise required.*

CVEScoreSource – An attribute that captures the source of the CVSS score (and the metrics used to calculate the score) for the CVE. Values for this attribute shall be only one of the following:

- NVD
- ADP
- CNA

[CDM PMO]

CVEScoreVersion – An attribute that captures the version of the CVSS score for the CVE. [CDM PMO]

CVEType – An attribute that captures the type of vulnerability, currently defined as the Common Weakness Enumeration Identifier(s) (CWE IDs), under which the CVE is categorized. [CDM PMO]

KEVDateAdded – An attribute that captures the date the KEV was added to the catalog. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because not all CVEs are KEVs.)*

KEVDescription – An attribute that captures a brief description of the KEV. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

KEVDueDate – An attribute that captures the date the required action is due. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

KEVInCatalog – An attribute that captures whether the KEV is present in the catalog. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

KEVKnownRansomwareUse – An attribute that captures whether the KEV has been associated with a ransomware campaign. Values for this attribute shall be one and only one of the following:

- KNOWN
- UNKNOWN

[CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

KEVName – An attribute that captures the name of the vulnerability. [CDM PMO]**KEVNotes** – An attribute that captures a link to notes provided for the KEV. [CDM PMO]

KEVProduct – An attribute that captures the vulnerable product. [CDM PMO]

KEVRequiredAction – An attribute that captures the action required for mitigation. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

KEVVendor – An attribute that captures the vendor or project name for the vulnerability. [CDM PMO]

SSVCExploitation – An attribute that captures how much evidence currently exists that the vulnerability is being exploited. The present state of exploitation of the vulnerability can be "none," "poc." or "active". [CDM PMO]

SSVCAutomatable – An attribute that captures if an attacker can reliably automate all four steps

(reconnaissance, weaponization, delivery, exploitation) of the kill chain or if the vulnerability allows remote code execution or command injection. The automatable value for the vulnerability can be either "YES" or "NO". [CDM PMO]

SSVCTechnicalImpact – An attribute that captures how much control of a system an attacker can gain. The technical impact of the vulnerability can be "PARTIAL" or "TOTAL". [CDM PMO]

CyHyFinding – An entity that captures a specific CyHy reported vulnerability or finding detail. [CDM PMO] [REQUIRED]

CyHyClosedDate – An attribute that captures the date of finding (ticket) closure. [CyHy]

CyHyConfirmedAge – An attribute that captures the calculated age, in days, of a finding based upon the difference between the original discovery date of the finding and the last time the finding was scanned/detected. [CyHy]

CyHyCVSSBaseScore – An attribute that captures the CyHy-provided CVSS base score (may be estimated for non-CVE findings based on CyHy-specific tool calculations). [CyHy]

CyHyDescription – An attribute that captures the informational description or explanation of a specific finding. [CyHy]

CyHyFindingID – An attribute that captures a unique identifier for a CyHy finding. [CDM PMO] [REQUIRED]

CyHyInitialDetection – An attribute that captures the time stamp (date/time) when the finding was first detected. [CyHy] [REQUIRED]

CyHyIPAddress – An attribute that captures the IP address (e.g., host) of the scanned device. [CyHy]

CyHyLatestDetection – An attribute that captures the time the CyHy scanner last detected a specific finding. [CyHy]

CyHyName – An attribute that captures the name of the specific finding (e.g., "Cross Side") [CyHy]

CyHyOwner – An attribute that captures the organization that owns an IP address of a device associated with a finding. [CyHy]

CyHyPort – An attribute that captures the number of the vulnerable port. [CyHy]

CyHySeverity – An attribute that captures the (modified) CVSS v2.0 severity rating (includes critical). [CyHy] [REQUIRED]

CyHySolution – An attribute that captures the mitigation/fix to resolve a finding. [CyHy]

CyHySource – An attribute that captures the (tool) source of a finding (e.g., "Nessus"). [CyHy]

CyHySourceID – An attribute that captures the source-specific identifier of a finding (e.g., the scanner plugin identifier that detected the vulnerability). [CyHy]

DeviceInterface – An entity that captures an active device interface (or interfaces) using IP to communicate across an agency's network. [CDM PMO] [REQUIRED]

InterfaceName – An attribute that captures the machine-assigned or configured label for the interface associated with a **DeviceIPAddress**. [CDM PMO] [REQUIRED]

IPAddress – An attribute that captures the last known (discovered) IP address(es) configured on each device (e.g., computer, printer) participating in a computer network using IP for communication. This

attribute has the following allowable formats:

- IPv4 valid range: 0.0.0.0 – 255.255.255.255, excluding any reserved IP addresses (e.g., 0.0.0.0, 240.0.0.0/4, and 255.255.255.255)
- IPv6 valid range: 0:0:0:0:0:0:0:0 – FFFF:FFFF:FFFF:FFFF:FFFF:FFFF:FFFF:FFFF

[CDM PMO] [REQUIRED]

(***Note:*** *This should be the last known/sensed "good" IP addresses assigned to the actual device. Subsequent IP addresses affirmatively discovered to belong to a device should take precedence over obsolete IP address assignments*.)

IPAddressAgencyOwned – A Boolean attribute that captures a value that indicates whether the IP address identified for a device is owned or used by the agency identified for the device (e.g., IP address falls within the known managed IP address space of an agency). [FY 20 CIO FISMA Metrics]

MACAddress – An attribute that captures a media access control (MAC) address that is associated with each **DeviceInterface**. [CDM PMO] [REQUIRED]

DeviceOnNetwork – An entity that captures information about hardware assets that are in scope for CDM. This entity is considered the fundamental record of the MDR construct. (See **DeviceOnNetwork** in Data Model Key Terms and the Master Device Records (MDR): Unique Identification of Hardware Devices section for additional context*). [Attach N 1.4.1]* [CDM PMO] [REQUIRED]

DateAssignedToSystemBoundary – An attribute that captures the date that a managed asset (i.e., device or managed application) was last assigned to a **SystemBoundary** (i.e., FISMA/Information System). [CDM PMO] [REQUIRED]

DateHardwareInventoryUpdated – An attribute that captures the date a hardware device's inventory information record was last updated with data from any source/tool/sensor that is relevant for discovery, scanning, or otherwise detecting hardware device data. (***Note:*** *This attribute should reflect the last time that a hardware device was "seen" or updated through a discovery or scanning process, even if no values have changed since the last discovery*.) [CDM PMO] [REQUIRED]

DeviceAuthorizationStatus – An attribute that captures an agency's policy assessment of whether a device is authorized to be on a network. [CDM PMO] [REQUIRED]

DeviceCategory – An attribute that captures the FISMA-defined device role of a discovered device within the CDM inventory. The values of this attribute are fixed and are defined by the CDM PMO. The valid values for **DeviceCategory** shall be **one**[18] and only one of the following values:

- ENDPOINT – Both physical and virtual endpoints
- ENTERPRISE IOT
- HEALTHCARE IOT
- MOBILE DEVICE
- NETWORKING DEVICE – Both physical and virtual
- OT
- OTHER INPUT/OUTPUT (I/O) DEVICE – Other I/O devices not explicitly called out

[18] Devices that fall under multiple categories should be assigned only to the **one** category that best describes the asset.

[FY24 CIO FISMA Metrics] [REQUIRED]

DeviceType – An attribute that captures a subtype that can be used to typecast devices to traditionally understood groupings, which may be one or more of the following values:

Subtypes of DeviceCategory: ENDPOINT

A. SERVERS – Mainframes, minicomputers, midrange computers
B. WORKSTATIONS – Desktops, laptops, and netbooks
C. VIRTUAL MACHINES – Virtual machines or applications that can be addressed
D. OT ENGINEERING WORKSTATION
E. OT CONTROL SERVER
F. OT DATA HISTORIAN
G. OT HMI ON IT

Subtypes of DeviceCategory ENTERPRISE IOT

A. CAMERA
B. PHYSICAL ACCESS CONTROLS
C. MOTION SENSOR
D. GROUND RESPONSE ROBOT
E. OTHER ENTERPRISE IOT

Subtypes of DeviceCategory HEALTHCARE IOT

F. IMAGING – X-RAY, MRI, etc.
G. PATIENT MONITORING – BLOOD PRESSURE, THERMOMETERS, etc.
H. PATIENT CARE – PUMPS, IV, VENTILATORS, etc.
I. OTHER HEALTHCARE IOT

Subtypes of DeviceCategory: MOBILE DEVICE

A. SMARTPHONE
B. TABLET
C. MOBILE DEVICE – OTHER, NOT PREVIOUSLY SPECIFIED

Subtypes of DeviceCategory: NETWORKING DEVICE

A. MODEMS
B. ROUTERS
C. SWITCHES
D. BRIDGING DEVICES
E. GATEWAY DEVICES – to/from internet or other external networks
F. WIRELESS ACCESS POINTS

G. INTRUSION DETECTION SYSTEMS

H. INTRUSION PREVENTION SYSTEMS

I. FIREWALLS

J. NETWORK ADDRESS TRANSLATORS – NAT devices

K. HYBRID NETWORK ADDRESS TRANSLATORS (e.g., NAT routers)

L. LOAD BALANCERS

M. VPNs

N. ENCRYPTORS/DECRYPTORS

O. PUBLIC KEY INFRASTRUCTURE (PKI)

Subtypes of DeviceCategory OT

A. CONTROLLER

B. EMBEDDED HMI

C. OTHER OT

Subtypes of DeviceCategory: OTHERIODEVICE

A. PRINTERS – Plotters, copiers, multifunction devices

B. SCANNERS (including cameras)

C. FAX PORTALS

D. ACCESSIBLE STORAGE DEVICES

E. VOICE OVER INTERNET PROTOCOL PHONES

F. OTHER INFORMATION SECURITY MONITORING DEVICES (e.g., network security appliances)

G. OTHER DEVICES ADDRESSABLE ON THE NETWORK

*(**Note:** DeviceType subtypes are not expected to yield new device data for a specified subtype.)*

[CDM PMO] [REQUIRED]

DeviceEncrypted – An attribute that captures the status indicating whether all the device's relevant datastores are encrypted.[19] [CDM PMO] [REQUIRED]

DeviceExposedToInternet – An attribute that captures a Boolean value indicating where a device is exposed to the internet through at least one port "listening" or open for internet traffic. [CDM PMO] [REQUIRED]

DeviceFQDN – An attribute that captures the FQDN of a device. [CDM PMO] [REQUIRED]

DeviceIPvEnabled – An attribute that captures the device IP version status as .gov transitions to IPv6-

[19] For CDM, datastores that should be encrypted include any persistently (i.e., non-volatile) attached (i.e., fixed or embedded) storage that is likely to contain sensitive data whose unauthorized disclosure would likely result in a formal security incident (i.e., sensitive PII, agency mission/business data, etc.).

only deployments. The values are one of the following:

- IPv4
- IPv6
- DUAL-STACK – Refers to deployments where IPv4 **and** IPv6 are enabled.

[CDM PMO]

DeviceManagedStatus – An attribute that captures the status indicating whether a device is managed or unmanaged. [CDM PMO] [REQUIRED]

DeviceModelVersion – An attribute that captures the specific model and version of a device (e.g., "Latitude E7250," "MacBook Air 13 2018"). [CDM PMO] [REQUIRED]

DeviceOnNetworkID – An attribute that captures a universally unique identifier that references a device discovered within the CDM inventory. The agency's CDM solution shall be able to search, locate, or otherwise identify an IT asset operating within an agency solely by querying by this attribute. The CDM PMO has no specific requirements on how to derive this attribute other than stipulating its uniqueness. This is the primary index value of the MDR construct. [CDM PMO] [REQUIRED]

***Additional Context*:** See 2.5.

DeviceOS – An attribute that captures the full name (i.e., name of OS, major version of OS, and release where applicable) of the primary OS of the device (e.g., Windows 11 64-bit, macOS 11 [Big Sur], Windows Server 2019). [CDM PMO] [REQUIRED]

DeviceSpecialTypeWindowsActiveDirectoryServiceRunning – An attribute that captures a Boolean value for a device that has Windows Active Directory service running. [CDM PMO] [REQUIRED]

DeviceSpecialTypeWindowsExchangeServiceRunning – An attribute that captures a Boolean value for a device that has Windows Exchange service running. [CDM PMO] [REQUIRED]

DeviceSpecialTypeWindowsDomainNameServiceRunning – An attribute that captures a Boolean value for a device that has Windows Domain Name Service running. [CDM PMO] [REQUIRED]

DeviceStatus – An attribute that captures the relevant, current disposition of a device in the CDM inventory, as informed by CDM tools/sensors:

- ACTIVE – Device is in an active state on the agency's network as recently detected by a CDM tool/sensor.
- ACTIVE-VETTED – For agencies employing CDM's network access protection capability: Device has been vetted against agency policies by the CDM system upon establishing a connection to the network, was allowed access, AND was recently inventoried and/or detected by any CDM tool/sensor.
- INACTIVE – Device has last seen timestamp of greater than > 14 calendar days and less than < 30 calendar days.
- STALE – (1) Devices whose source DeviceScanMethods are Agent-based and/or Network-based Active Scans that are pending removal and have not been seen by the authoritative reporting sensor in >= 30 calendar days, yet whose datasets are present in data store; or (2) Devices that are categorized as ENTERPRISE IOT, HEALTHCARE IOT or OT and whose sole source DeviceScanMethods are Network-based Passive Discovery Scans, and have not been seen by the authoritative reporting sensor in >= 60 calendar days, yet whose datasets are present in data

store.

[CDM PMO] [REQUIRED]

DeviceVendor – An attribute that captures the vendor (manufacturer) of a device (e.g., Dell Inc., HP Inc.). [CDM PMO] [REQUIRED]

EndpointSecurityUpdateDate – An attribute that captures the date a device's endpoint security product (e.g., endpoint protection platforms, audio-visual solutions) last received a security-relevant update (e.g., signature updates, DAT/definition file updates, threat indicator/pattern updates). [CDM PMO] [REQUIRED]

HighValueAssetFlag – An attribute that captures the flag indicating whether a device is a high-value asset or not. [CDM PMO] [REQUIRED]

IsEphemeral – An attribute that captures a Boolean value indicating whether a device is ephemeral or not (i.e., a container or third-party-managed SaaS solution). [BOD 23-01] [REQUIRED]

DeviceSubComponent – An entity that captures a hardware subcomponent of a device (e.g., CPU, hard disk drive). [CDM PMO]

DeviceSubComponentDescription – An attribute that captures a textual description of a device subcomponent. [CDM PMO]

DeviceSubComponentModel – An attribute that captures the model name/identifier of a device subcomponent (e.g., Core-i5 8550U). [CDM PMO]

DeviceSubComponentType – An attribute that captures the type of a device subcomponent as:

- PROCESSOR (central processing unit of system)
- DISK (physical solid state, magnetic disks installed/fixed within a hardware device)
- OTHER (agency-specific subcomponent captured)

[CDM PMO]

DeviceSubComponentVendor – An attribute that captures the name of the vendor that makes the device subcomponent (e.g., Intel, AMD). [CDM PMO]

DeviceSubComponentID – An attribute that captures a partial identifier for each device subcomponent within an agency's network. [CDM PMO]

DeviceScan – An entity that captures information relating to the results of device scans produced by CDM tools/sensors on agency networks. [CDM PMO] [REQUIRED]

Credentialed – A Boolean attribute that captures the type of device scan as either TRUE (i.e., an attempted credentialed scan) or FALSE. [CDM PMO] [REQUIRED]

DeviceScanAuthOutcome – An attribute that captures the authentication result of a credentialed device scan, which shall be only one of following:

- SUCCESS (i.e., scan was successfully authenticated to produce detailed scan data)
- FAIL (i.e., scan was unsuccessfully authenticated and did not produce detailed scan data)

Any agent-based scan is expected to be successfully credentialed. Where both network- and agent-based

scans apply to a given device, the agent-based scan is expected to supersede. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because it applies only if the scan is a credentialed scan—i.e., Credentialed = "TRUE.")*

DeviceScanDate – An attribute that captures the date and time a device scan completed. [CDM PMO] [REQUIRED]

DeviceScanID – An attribute that captures a unique identifier for each device scan recorded/conducted within an agency's network. [CDM PMO] [REQUIRED]

DeviceScanMethod – An attribute that captures what VUL method was used to detect the vulnerability on the device, which shall be one of the following values:

- Agent-based
- Network-based Active Scan
- Network-based Passive Discovery

[CDM PMO]

DeviceScanType – An attribute that captures the type of information produced by the device scan performed on a device. This attribute shall be one or more of the following:

- CSM (producing misconfiguration information traceable to one or more benchmarks)
- VUL (producing vulnerability information/CVEs)
- MTD (producing mobile vulnerability information)
- EMM (producing mobile asset inventories)
- SWAM (producing authorized software information through the AEC sub-capability and software inventory updates)
- HWAM (producing hardware asset management information)

[CDM PMO] [REQUIRED]

ScanBenchmarkTitleName – An attribute that captures the title of the benchmark used in the CSM scan. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the CSM scan.)*

ScanBenchmarkVersion – An attribute that captures the version of the benchmark used in a CSM scan. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the CSM scan.)*

EventOnNetwork – An entity that captures an "observable occurrence in a system or network" inventoried in the CDM solution due to a correlation to occurring agency network activities. The event is likely part of a suspected or confirmed security incident, as reported by a CDM tool/sensor based upon defined parameters (e.g., agency or CDM policy-based triggers/alerts). (See **Event** in Data Model Key Terms for additional context) [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the **Event Management** security capabilities necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ **Event Management**.)*

EventName – An attribute that captures a descriptive name/title for an event (e.g., Generic ICMP Event, Unauthorized File Transfer Protocol [FTP] Attempt, Malicious Script Detected). [CDM PMO]

EventOnNetworkID – An attribute that captures a unique identifier for each event that occurs on an agency's network that has been analyzed and attributed to the timeline of an incident or suspicious activity on the agency's network. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

EventRawData – An attribute that captures that raw event message (e.g., entire log entry in its original state, such as Common Event Format, Log Event Extended Format, Syslog message, etc.) as reported from the agency tool. [CDM PMO]

EventSeverity – An attribute that captures the agency-defined, normalized, severity rating (e.g., Generic ICMP Event, Priority: 3, Unauthorized Access detected: Critical Priority, etc.) of the incident-related event as reported by the agency tool. [CDM PMO]

*(**Note:** Required only if the tool provides this data natively and the agency implements a severity schema that enables this data to be useful.)*

EventTimeStamp – An attribute that captures the time stamp (i.e., date, time, and time zone) when the tool triggered and reported the event. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

EventType – An attribute that captures information that identifies the type or category of the **EventOnNetwork** record as predefined by the CDM PMO or tailored by an agency tool or process. The value of this attribute may be one of the following values:

- MALICIOUS EVENT ALERT – Suspicious information discovered on the network that may be suspected or confirmed to be part of malicious activities to compromise the security of the agency's IT infrastructure
- NETWORK ACCESS PROTECTION EVENT – CDM tool/sensor that supports network access protection/NAC reports some policy violation based upon recently connected devices)
- OTHER (AGENCY DEFINED)

[CDM PMO] [CONDITIONALLY REQUIRED] *(Conditionally required; see above.)*

Facility[20] – An entity that captures the relevant characteristics of a physical site, hosting provider (e.g., Amazon Web Services GovCloud), location housing physical IT assets (e.g., endpoints, subcomponents of a FISMA system), and/or agency personnel (See **Facility** in Data Model Key Terms for additional context.)

FacilityID – An attribute that captures a unique identifier for a specific facility. [CDM PMO] [REQUIRED]

FacilityLocation – An attribute that captures the address for a specific facility. [CDM PMO]

FacilityName – An attribute that captures an agency-specified common name for a specific facility (e.g., San Antonio Data Center). [CDM PMO]

FacilityType – An attribute that captures the type of facility that the physical site most closely resembles. If populated, the entity shall be one or more of the following values:

- AGENCY DATA CENTER – Site that holds a high concentration of data processing equipment (e.g., servers, network equipment)
- COLOCATION

[20] The term "facility" is to be interpreted as a set of data that indicates or approximates the physical location of IT assets associated with the data entity (i.e., users, devices, etc.). This entity is not to imply, specify, or relate to any physical security requirements or controls traditionally associated with the NIST PE family of controls (physical access).

- HOSTING PROVIDER – Including cloud service providers
- OFFICE – Any site that houses IT assets and agency personnel performing day-to-day activities; official duty station(s)
- CAMPUS/HQ
- STORAGE – Any site that holds offline IT assets for disposition or delivery (e.g., warehouse, logistics depot)

[CDM PMO]

IncidentActor – An entity that represents information regarding an actor principally involved in or responsible for the cause of the **IncidentThreatAction**. [VERIS]

IncidentActorActionNote – An attribute that captures any additional agency information providing context to the **IncidentActor** in relation to the incident on the agency's network. [VERIS]

IncidentActorCategory – An attribute that captures, for an actor that is external to the agency, the category group the actor is most representative of. This attribute may be one of the following:

- ACTIVIST (activist group)
- AUDITOR (auditor)
- COMPETITOR (competitor)
- CUSTOMER
- ENVIRONMENTAL
- FORMER EMPLOYEE (former employee; no longer had access)
- NATION-STATE
- CRIMINAL (organized or professional criminal group)
- ACQUAINTANCE (relative or acquaintance of employee)
- STATE AFFILIATED (state-sponsored or -affiliated group)
- TERRORIST (terrorist group)
- UNAFFILIATED (unaffiliated person that is unknown to the organization)
- UNKNOWN
- OTHER

[VERIS]

IncidentActorID – An attribute that captures a unique identifier for each **IncidentActor**. [VERIS]

IncidentActorName – An attribute that captures the name of an individual person, party, and/or any organizational name/designation associated with the **IncidentThreatAction**. [VERIS]

IncidentActorOrigin – An attribute that captures the geographic origin (country) of the **IncidentActor**. [VERIS]

IncidentActorRelationship – An attribute that captures the relationship of each **IncidentActor** to the organization. The attribute shall be one of the following:

- INTERNAL – a party/person internal to the organization (e.g., employee)
- EXTERNAL – any party external to the organization with no predefined relationship, such as nation-states, advanced persistent threats, criminal groups, etc.
  - PARTNER – any group/person with a professional relationship to the organization not granted "internal" access, such as vendors, contracted building custodial staff, security, etc.

[VERIS]

IncidentOnNetwork – An entity that represents a suspected or confirmed, reportable information security incident that has occurred within an agency's network and might negatively impact the confidentiality, integrity, and/or availability of an information system or its assets. (See **Incident** in Data Model Key Terms for additional context.) [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the **Incident Management** security capabilities necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ **Incident Management**.)*

CIAImpacted – An attribute that captures whether the confidentiality, integrity, or availability of an organization's information system(s) (i.e., FISMA system) were potentially compromised. [Federal Incident Notification Guidelines]

IncidentClassification – An attribute that captures whether a reported incident has been classified as a "Major Incident" by the agency.[21] A "Major incident" requires congressional notification within seven days of identification. [Federal Incident Notification Guidelines]

IncidentDescription – An attribute that captures a brief description of a reported incident that occurred on an agency's network. [Federal Incident Notification Guidelines]

IncidentDetectDate – An attribute that captures the date when any activity associated with a reported incident was first detected. [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(Conditionally required; see above.)*

IncidentDetectTime – An attribute that captures the time (including time zone) when any activity associated with a reported incident was first detected. [Federal Incident Notification Guidelines]

IncidentDetermination – An attribute that captures the authenticity and status of the incident. The attribute shall be only one of the following values:

- SUSPECTED (proposed for further analysis/follow-up; captured as a tentative record from some preliminary information)
- CONFIRMED (subject to some agency governed process; has been analyzed and determined to be a confirmed incident within the agency)

[CDM PMO]

IncidentDeterminationDate – An attribute that captures the date the **IncidentDetermination** attribute was set to CONFIRMED. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

IncidentDeterminationTime – An attribute that captures the time (including time zone) the **IncidentDetermination** attribute was set to CONFIRMED. [CDM PMO]

[21] Refer to the most recent OMB guidance for assistance with designation of a "Major Incident." Agencies may also consult with CISA to facilitate this determination.

IncidentFunctionalImpact – An attribute that captures whether the incident functionally impacted the organization. A functional impact is a measure of the actual, ongoing impact to the organization. In many cases (e.g., scans and probes, or a successfully defended attack), little or no incident impact may be experienced. This attribute may have **one** of the following categorical values as defined by CISA:

- NO IMPACT – Event has no impact.
- NO IMPACT TO SERVICES – Event has no impact on any business or ICS services or delivery to entity customers.
- MINIMAL IMPACT TO NON-CRITICAL SERVICES – Event has low level of impact on non-critical systems and services.
- MINIMAL IMPACT TO CRITICAL SERVICES – Event has minimal impact, but the area impacted is a critical system or service, such as email or Active Directory.
- SIGNIFICANT IMPACT TO NON-CRITICAL SERVICES – Event has a significant impact on a non-critical service or system.
- DENIAL OF NON-CRITICAL SERVICES – Event denies or destroys a non-critical system.
- SIGNIFICANT IMPACT TO CRITICAL SERVICES – Event has significant impact on a critical system, such as a local administrative account.
- DENIAL OF CRITICAL SERVICES/LOSS OF CONTROL – Event renders a critical system unavailable.

[Federal Incident Notification Guidelines]

IncidentFunctionalImpactDescription – An attribute that captures the justification for the reported incident's functional impact designation, including any supplemental information describing the downstream impacts (e.g., mission impacts, business impacts, financial or safety considerations). [Federal Incident Notification Guidelines]

IncidentInformationImpact – An attribute that indicates whether the incident had information impact on the organization. Incidents may affect the confidentiality and integrity of the information stored or processed by various systems. The information impact category describes the type of information lost, compromised, or corrupted. This attribute shall be one or more of the following categorical values as defined by CISA:

- NO IMPACT – Event has no known data impact.
- SUSPECTED BUT NOT IDENTIFIED – A data loss or impact to availability is suspected, but no direct confirmation exists.
- PRIVACY DATA BREACH – The confidentiality of PII or personal health information (PHI) was compromised.
- PROPRIETARY INFORMATION BREACH – The confidentiality of unclassified proprietary information, such as protected critical infrastructure information (PCII), intellectual property, or trade secrets, was compromised.
- DESTRUCTION OF NON-CRITICAL SYSTEMS – Destructive techniques, such as master boot record (MBR) overwrite, have been used against a non-critical system.
- CRITICAL SYSTEMS DATA BREACH – Data pertaining to a critical system has been exfiltrated.
- CORE CREDENTIAL COMPROMISE – Core system credentials (such as domain or enterprise

administrative credentials) or credentials for critical systems have been exfiltrated.

- DESTRUCTION OF CRITICAL SYSTEM – Destructive techniques, such as MBR overwrite, have been used against a critical system.

[Federal Incident Notification Guidelines]

IncidentInformationImpactDescription – An attribute that captures the justification for the reported incident's information impact categorization, including any supplemental information that further describes the information impacted—including, but not limited to, specific descriptors of the information or credentials impacted and justification on why data may/may not be critical to the enterprise. [Federal Incident Notification Guidelines]

IncidentNetworkLocation – An attribute that captures observed activity related to the reported incident and that is categorized using the CISA definition. Categorization shall be one or more of the following:

- LEVEL 0 – UNSUCCESSFUL – Existing network defenses repelled all observed activity.
- LEVEL 1 – BUSINESS DEMILITARIZED ZONE – Activity was observed in the business network's demilitarized zone (DMZ). These systems are generally untrusted and are designed to be exposed to the internet. Examples are a company's web server or email server.
- LEVEL 2 – BUSINESS NETWORK – Activity was observed in the business or corporate network of the victim (i.e., corporate user workstations, application servers, and other non-core management systems).
- LEVEL 3 – BUSINESS NETWORK MANAGEMENT – Activity was observed in business network management systems, such as administrative user workstations, Active Directory servers, or other trust stores.
- LEVEL 4 – CRITICAL SYSTEM DMZ – Activity was observed in the DMZ that exists between the business network and a critical system network. These systems may be internally facing services, such as SharePoint sites, financial systems, or relay "jump" boxes into more critical systems.
- LEVEL 5 – CRITICAL SYSTEM MANAGEMENT – Activity was observed in high-level critical systems management, such as human-machine interfaces in ICSs.
- LEVEL 6 – CRITICAL SYSTEMS – Activity was observed in the critical systems that operate critical processes, such as programmable logic controllers in ICS environments.
- LEVEL 7 – SAFETY SYSTEMS – Activity was observed in critical safety systems that ensure the safe operation of an environment. One example of a critical safety system is a fire suppression system.
- UNKNOWN – Activity was observed, but the network segment could not be identified.

[Federal Incident Notification Guidelines]

IncidentOnNetworkID – An attribute that captures an agency's assigned unique identifier for an incident on the agency's network that has been captured and reported (e.g., incident tracking number). [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

IncidentPrimaryAttackVector – An attribute that captures the attack vector(s) that led to the reported incident, as determined by the agency. To facilitate a common set of terms and relationships between government

security teams, CDM will use a common taxonomy provided by CISA as developed from NIST SP 800-61 Rev. 3. The value of this attribute shall be one or more of the following types:

- UNKNOWN – Cause of attack is unidentified. This option is acceptable if cause (vector) is unknown upon initial report. The attack vector may be updated in a follow-up report.
- ATTRITION – An attack that employs brute force methods to compromise, degrade, or destroy systems, networks, or services (e.g., denial of service [DoS] attack intended to impair or deny access to an application; a brute force attack against an authentication mechanism, such as passwords or digital signatures).
- WEB – An attack executed from a website or web-based application (e.g., a cross-site scripting attack used to steal credentials; a redirect to a site that exploits a browser vulnerability and installs malware).
- EMAIL/PHISHING – An attack executed via an email message or attachment (e.g., exploit code disguised as an attached document; a link to a malicious website in the body of an email message).
- EXTERNAL/REMOVABLE MEDIA – An attack executed from removable media or a peripheral device (e.g., malicious code spreading onto a system from an infected flash drive).
- IMPERSONATION/SPOOFING – An attack involving replacement of legitimate content/services with a malicious substitute (e.g., spoofing, man-in-the-middle attacks, rogue wireless access points, and structured query language [SQL] injection attacks).
- IMPROPER USAGE – Any incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding the above categories (e.g., a user installs file-sharing software, leading to the loss of sensitive data; a user performs illegal activities on a system).
- LOSS OR THEFT OF EQUIPMENT – The loss or theft of a computing device or media used by the organization (e.g., a misplaced laptop or mobile device).
- OTHER – An attack method that does not fit into any other vector.

[Federal Incident Notification Guidelines]

(***Note:*** *In the CDM Data Model, subordinate* IncidentThreatAction*(s) may be associated with individual incidents that may facilitate determination of this value. The attribute* ThreatActionMethod*, if determined by agencies, can facilitate more discrete attack processes that can be used to determine the primary vector(s) for reporting.)*

IncidentRecoverability – An attribute that captures the CISA categorization of the scope of resources needed to recover from a reported incident. The attribute shall be classified as one of the following values:

- REGULAR – Time to recovery is predictable with existing resources.
- SUPPLEMENTED – Time to recovery is predictable with additional resources.
- EXTENDED – Time to recovery is unpredictable; additional resources and outside help are needed.
- NOT RECOVERABLE – Recovery from the incident is not possible (e.g., sensitive data is ex-filtrated and posted publicly).

[Federal Incident Notification Guidelines]

IncidentRecoverabilityDescription – An attribute that captures the justification for the reported incident's recoverability classification, including any supplemental information describing the type of outside resources needed. [Federal Incident Notification Guidelines]

IncidentRecoverabilityTime – An attribute that captures an estimate of how much time is required (in days) to recover from the reported incident, if known. [Federal Incident Notification Guidelines]

IncidentReportDate – An attribute that captures the date the incident was reported to CISA. [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

IncidentStartDate – An attribute that captures the start date the reported incident. [Federal Incident Notification Guidelines]

> (***Note***: *This attribute should reflect the projected/confirmed time that the incident started (i.e., when the incident started impacting the agency), which is distinct from the date the agency confirmed the incident. Incident start date/times might occur through subsequent investigation and analysis of events and other associated activity on the agency's network/assets once a declaration of existence of an incident is made.*)

IncidentStartTime – An attribute that captures the time (including time zone) the reported incident started. [Federal Incident Notification Guidelines]

> (***Note:*** *This attribute should reflect the projected/confirmed time that the incident started (i.e., when the incident started impacting the agency), which is distinct from the date the agency confirmed the incident. Incident start date/times might occur through subsequent investigation and analysis of events and other associated activity on the agency's network/assets once a declaration of existence of an incident is made.*)

CISARiskRating – An attribute that captures the CISA assigned risk rating based on the CISA National Cyber Incident Scoring System (NCISS). [Federal Incident Notification Guidelines]

> *(**Note:** This information will be provided by the CDM federal dashboard upon receipt, confirmation, and adjudication of the reported incident by DHS.)*

CISATrackingNumber – An attribute that captures the CISA assigned tracking identifier, as assigned from CISA upon submission of the incident report to DHS. [Federal Incident Notification Guidelines]

> *(**Note:** This information will be provided by the CDM federal dashboard upon receipt, confirmation, and adjudication of the reported incident by DHS.*

IncidentThreatAction – An entity that represents some distinct action or event that occurred, which contributed significantly to the cause of the incident (**IncidentOnNetwork**). [VERIS] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the **Incident Management** security capabilities necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ **Incident Management**.)*

> **IncidentThreatActionID** – An attribute that captures a unique identifier pertaining to a specific **IncidentThreatAction**. [VERIS] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*
>
> **ThreatActionAgencyNote** – An attribute that captures any additional agency information that is relevant to the **IncidentThreatAction**. [VERIS]
>
> **ThreatActionCategory** – An attribute that captures a category for the **IncidentThreatAction**. The

attribute shall be one of the following values:

- MALWARE – Installed malware, which includes viruses, worms, and keyloggers.
- HACKING – Attempts to circumvent security mechanisms, which include DoS and SQL injections.
- SOCIAL – Social engineering.
- MISUSE – Policy violations, use of non-approved software or hardware, and admin abuse resulting from granted access/privileges, etc.
- ERROR – Unintentional mistakes, errors, misconfigurations, loss devices, etc. that result in an incident.
- PHYSICAL – Theft, snooping, sabotage, etc.
- ENVIRONMENTAL – Natural disasters, power failures, etc.
- UNKNOWN – This option is acceptable if the root cause or vector used in the ThreatAction is unknown upon initial report of the **IncidentOnNetwork**. It allows the **IncidentThreatAction** to be instantiated such that devices can be tied to the incident. It may be updated in a follow-up report or submission of incident data.

[VERIS] [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

ThreatActionDate – An attribute that captures the date the **IncidentThreatAction** occurred. [VERIS]

ThreatActionMalwareStrain – For each **IncidentThreatAction** that is categorized as *MALWARE*, this is an attribute that captures a common name or known identifier for the strain of malware as identified by any authoritative source the agency may have (e.g., AV tool, threat management tool, endpoint security tool). [VERIS] [MAEC] *(**Note:** This information might not be relevant to some **IncidentThreatAction** entities, or malware might not be easily identifiable.)*

ThreatActionMethod – An attribute that captures the primary method(s) ("vectors" in VERIS) used to execute the **IncidentThreatAction** based on the **ThreatActionCategory**. [VERIS] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

ThreatActionPattern – An attribute that captures reference(s) to attack pattern(s), if known, using CAPEC catalog numbers and titles (e.g., CAPEC 242 – Code Injection, CAPEC 163 – Spear Phishing). This attribute provides a method to normalize a threat action to MITRE's CAPEC™ catalog. [CAPEC]

ThreatActionVariety – An attribute that captures the relevant malicious threat activity classifications pertaining to an **IncidentThreatAction** based on the **ThreatActionCategory**.[VERIS] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

(***Note:*** *The exhaustive list of possible values is too extensive to be provided here. Refer to APPENDIX C for the fully enumerated set of possible values.*)

IndicatorOfCompromise – An entity that represents an incident-related IOC. [Federal Incident Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** Conditionally required because some agencies may not have access to the **Incident Management** security capabilities necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ **Incident Management**.)*

IndicatorOfCompromiseID – An attribute that captures a unique identifier that pertains to a specific **IndicatorOfCompromise** associated with an incident on an agency's network. [Federal Incident

Notification Guidelines] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

IndicatorOfCompromiseData – An attribute that captures the raw data associated with the IOC (e.g., file hash, domain name, IP address, signature), [Federal Incident Notification Guidelines]

IndicatorOfCompromiseDescription – An attribute that captures any context related to the IOC (e.g., type of IOC, location where IOC is likely to be seen, other descriptive information). [Federal Incident Notification Guidelines]

MaliciousEventOnNetwork [*EventOnNetwork Specialization*] – An entity that is a specialization of **EventOnNetwork** representing an event suspected to be caused by malicious actor or activities, as detected by CDM tools/sensors that filter, inspect, or analyze network/device activity for known or suspected threats. [CDM PMO]

MaliciousEventAction – An attribute that captures, if applicable, any manual or automated response/actions taken by agency staff or security tools to mitigate the malicious network activity identified (e.g., ran playbook, took device offline, dropped/blocked connection or session, killed process, quarantined malware). [CDM PMO]

MaliciousEventApplicationProtocol – An attribute that captures the application protocol that was observed as part of the malicious event (e.g., FTP, Secure Shell, Hypertext Transfer Protocol, Secure Sockets Layer [SSL]/Transport Layer Security [TLS], TELNET, RDP). [CDM PMO]

MaliciousEventDstHostName – An attribute that captures, if applicable, the identifying string (e.g., hostname, URL, URI) of the destination host/device/resource within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

MaliciousEventDstIP – An attribute that captures, if applicable, the destination IP address (IPv4 or IPv6) of a host/device/resource within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

MaliciousEventDstPort – An attribute that captures, if applicable, the destination port (0 – 65535) of a host/device/resource within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

MaliciousEventReportingReason – An attribute that captures the basis (e.g., signature match, behavior anomalies triggered, matching threat indicators) for suspecting an event is malicious in nature and warrants further investigation or oversight. [CDM PMO]

MaliciousEventSrcHostName – An attribute that captures, if applicable, the identifying string (e.g., hostname, URL, URI) of the source host/device/resource within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

MaliciousEventSrcIP – An attribute that captures, if applicable, the source IP address (IPv4 or IPv6) of a host/device within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

MaliciousEventSrcPort – An attribute that captures, if applicable, the source port (0 – 65535) of a host/device within a recorded event (e.g., network session, observed activity) suspected to be malicious, as detected by a tool/sensor. [CDM PMO]

ManagedAppOnNetwork – An entity that represents a defined application that is under discrete risk management and accountability. (See **Managed Applications** in Data Model Key Terms for additional context.)

[CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because it may not apply to a particular agency's FISMA containerization needs and related solution implementation.)*

ManagedAppDescription – An attribute that captures any relevant descriptive information in relation to the managed application. [CDM PMO]

ManagedAppOnNetworkID – An attribute that captures a value that uniquely identifies a managed application within the inventory of an agency. [CDM PMO] [REQUIRED]

ManagedAppNamespace – An attribute that captures a label or name of an application that is supported by one or many detected instances of installed software (e.g., website URL, custom app name). [CDM PMO]

MisconfigurationOnNetwork – An entity that represents a single discovered misconfiguration on an agency device. Misconfigurations are a deviation from the benchmark settings selected by the Agency for any particular device, class of devices or applications, and represent a potential IT security risk that should be addressed. (See **Benchmark** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

ConfigurationCheckSource – An attribute that captures a value that identifies the author organization of a benchmark (i.e., DISA, CIS, NIST, NSA, etc.) [CDM PMO] [REQUIRED]

ConfigurationCheckDescription – An attribute that captures the CDM tool-specified description of the configuration setting: synopsis of the security setting, its security implications, and relevant operational impact. For example, the CSM scanner reports: *"Allowing anonymous logon users (null session connections) to list all account names and enumerate all shared resources can provide a map of potential points to attack the system."* [CDM PMO] [REQUIRED]

ConfigurationCheckFix – An attribute that captures the CDM tool-specified description of the needed setting(s) to pass the configuration audit (e.g., fix text or fix value[s]). For example, a CSM scanner reports the available mitigation actions to take: *"Set the following Group Policy setting to Enabled. Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Do not allow anonymous enumeration of SAM accounts and shares."* [CDM PMO] [REQUIRED]

ConfigurationCheckSeverity – An attribute that captures the severity of the configuration check as described by DISA STIG configuration check severity levels, CAT I = high severity, CAT II = medium severity, and CAT III = low severity. [CDM PMO] [CONDITIONALLY REQUIRED] (***Note:** Conditionally required based on the value of CCESource being equal to "DISA" in line with DISA content, i.e., low, medium, high.*)

ConfigurationCheckTitle – An attribute that captures the title of the unique configuration check. [CDM PMO] [REQUIRED]

CSMActualSetting – An attribute that captures the actual configuration setting discovered on the device, as reported by the CDM sensor (e.g., LmCompatibilityLevel in HKLM\SYSTEM\CurrentControlSet\Control\Lsa equals "3"). [CDM PMO] [REQUIRED]

CSMConfirmedFalsePositive – An attribute that captures, in a Boolean value, whether a misconfiguration is a confirmed false positive due to tool/sensor issues, or other reasons. [CDM PMO]

CSMExceptionDescription – An attribute that captures the justification or rationale associated with an agency's exception to a mandated configuration setting. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** This attribute is subject to the allowance of a CSM EXCEPTION [see **CSMStatus**]. If an exception is permitted, this field is required.)*

CSMOriginalDiscoveryDate – An attribute that captures the date when the **MisconfigurationOnNetwork** (i.e., deviation from expected configuration) was first discovered on a specific device. [CDM PMO] [REQUIRED]

CSMRemediationDate – An attribute that captures the date a misconfiguration was remediated (e.g., configuration software patched or removed). [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because the misconfiguration may not yet be remediated.)*

CSMStatus – An attribute that captures the status of a particular **MisconfigurationOnNetwork**. The attribute shall be one of the following:

- OPEN
- CSM EXCEPTION – Captures an agency's desire to allow exception to a mandated configuration setting on a particular device.
- REMEDIATED – Vulnerability has been remediated and is no longer being detected by tool/sensors.

[CDM PMO] [REQUIRED]

MisconfigurationOnNetworkID – An attribute that captures a value that uniquely identifies a captured security-related software misconfiguration as specified within a benchmark and/or agency-defined configuration baseline. (See **Benchmark** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

MobileDeviceOnNetwork [DeviceOnNetwork Specialization**]** – An entity that captures information about a mobile device (e.g., a cell phone, smartphone, tablet, pager, or other mobile device). **MobileDeviceOnNetwork** is a specialization (subclass) of **DeviceOnNetwork** that enumerates specific category devices with additional attributes and relationships that are important for the CDM solution to capture. [CDM PMO] [REQUIRED]

DeviceAbilityToRemoveEMM – An attribute that captures whether a mobile device user is able to remove the MDM/EMM profile without administrator approval. [CDM PMO] [REQUIRED]

DeviceAccessDeniableByAgency – An attribute that captures whether a mobile device enables agency capability to deny access to agency enterprise services. [CDM PMO] [REQUIRED]

DeviceAssignedPhoneNumbers – A multivalued attribute that captures the phone number(s) assigned to a mobile device with telephony capabilities (e.g., cellular telephone). [CDM PMO]

DeviceCoveredByMTD – An attribute that captures whether a mobile device is covered by an MTD solution. [CDM PMO] [REQUIRED]

DeviceIMEI – An attribute that captures the international mobile equipment identity (IMEI) or mobile equipment identifier (i.e., GUID) of a mobile device. [CDM PMO]

DeviceManagementServer – An attribute that captures the device name (e.g., FQDN), software-as-a-service name, URI, or other appropriate UID of the MDM/EMM server to which the mobile device is currently registered (enrolled). The MDM/EMM server is expected to be capable of and configured for authorization and remote wiping criteria when aligned with agency policy. [CDM PMO]

DeviceManagementRemoteWipe – An attribute that captures whether the management server is capable of and configured for authorization and remote wiping criteria when aligned with agency policy. [CDM PMO] [REQUIRED]

DeviceSerialNumber – An attribute that captures the serial number of a mobile device. [CDM PMO]

DeviceTelecomProviders – A multivalued attribute that captures the name of the telecom provider(s) serving a mobile device. [CDM PMO]

EMMLastSeenTimestamp – An attribute that captures the time stamp (date, time) when the mobile device last "checked in" (e.g., synchronized, reported back) with the management server (i.e., MDM/EMM) that the device is currently registered (enrolled) with, as reported by the MDM/EMM server. [CDM PMO] [REQUIRED]

NACEventOnNetwork [*EventOnNetwork Specialization*] – An entity that captures the raw event information reported by a CDM tool/sensor supporting the network access protection capability when that tool puts any device into a BLOCKED or QUARANTINED state (see **DeviceStatus** in Data Model Key Terms for more information). **NACEventOnNetwork** is a specialization (subclass) of **EventOnNetwork** (see **Network Access Protection** in Data Model Key Terms for additional context). [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have access to the **Event Management** security capabilities necessary to produce this data; therefore, the data is required only for certain CDM solutions that employ **Event Management**.)*

NACEventAction – An attribute that captures the action taken on an endpoint by NAC system that may be one of the following values:

- BLOCK
- QUARANTINE [CDM PMO]

NACEventActionReason – An attribute that captures the basis (i.e., rule/policy violation) for an NAC tool/sensor blocking or quarantining a connecting/connected device (e.g., missing patch, disabled antimalware application). [CDM PMO]

NACEventDeviceIP – An attribute that captures the IP address of the (connecting) device, which the CDM tool/sensor supporting the NAC capability was able to discover upon device connection to the network. [CDM PMO]

NACEventDeviceMAC – An attribute that captures the MAC address of the (connecting) device, which the CDM tool/sensor supporting the NAC capability was able to discover upon device connection to the network. [CDM PMO]

NACEventDeviceName – An attribute that captures the name (e.g., DNS/hostname) of the (connecting) device, which the CDM tool/sensor supporting the NAC capability was able to discover upon device connection to the network. [CDM PMO]

NACEventDeviceOSClassfication – An attribute that captures the OS (e.g., Windows, Ubuntu, macOS, IOS) of the (connecting) device, which the CDM tool/sensor supporting the NAC capability was able to discover upon the device being connected to the network. [CDM PMO]

NACEventDeviceTypeClassification – An attribute that captures the general type/kind of (connecting) device, which the CDM tool/sensor supporting the NAC capability was able to discover (or predict) upon device connection to the network. [CDM PMO]

NonCVEVulnerabilityOnNetwork – An entity that represents a single discovered vulnerability within an agency, but which is not further defined by a CVE that exists on software installed on an agency device and detected by a CDM tool or sensor. [CDM PMO] [REQUIRED]

DateofNonCVEVULScan – An attribute that captures the date of the last (most recent) vulnerability scan that found the vulnerability on a device within the agency's network. [CDM PMO] [REQUIRED]

(***Note:*** *This attribute should reflect the last time that a vulnerability was "seen" or updated through a scanning process. If no new relevant details about a vulnerability are discovered but the vulnerability is still seen, this attribute would be updated with the last date the sensor witnessed the vulnerability*.)

NonCVEVULConfirmedFalsePositive – An attribute that captures, in a Boolean value, whether a vulnerability is a confirmed false positive due to misconfigurations, tool/sensor issues, or other reasons. [CDM PMO]

NonCVEVULID – An attribute that captures a unique identifier referencing a specific discovered vulnerability on an agency's network. [CDM PMO] [REQUIRED]

NonCVEVulnerableSoftwareVendorName – An attribute that captures the software vendor name of the vulnerable software. [CDM PMO] [REQUIRED]

NonCVEVulnerableSoftwareCommonProductName – An attribute that captures the common product name of the vulnerable software. [CDM PMO] [REQUIRED]

NonCVEVulnerableSoftwareVersion – An attribute that captures the software version of the vulnerable software. [CDM PMO] [REQUIRED]

NonCVEVulnerableSoftwareCVEDetectionSignatureIdentifier – An attribute that captures a vendor-provided value that identifies the software module(s) used by the VUL tool to detect the vulnerability. [CDM PMO] [REQUIRED]

NonCVEVulnerableSoftwareInstallationFilePath – An attribute that captures the installation location of the vulnerable software. [CDM PMO] [REQUIRED]

NonCVEVULFixText – An attribute provided by the VUL tool that captures the clear and simple description of how to correct the vulnerability; this includes the version of the software that remediates the vulnerability. [CDM PMO] [REQUIRED]

NonCVEVULOriginalDiscoveryDate – An attribute that captures the date when the **NonCVEVulnerabilityOnNetwork** was first discovered. [CMD PMO] [REQUIRED]

NonCVEVULRemediationDate – An attribute that captures the date a vulnerability was remediated (e.g., vulnerable software patched or removed). [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because the vulnerability may not yet be remediated.)*

NonCVEVULStatus – An attribute that captures the status of a particular non-CVE.

NonCVEVulnerabilityOnNetwork. The attribute shall be one of the following:

- OPEN
- RISK ACCEPTED – Vulnerability has currently been accepted and is not expected to be remediated due to some exigent circumstances.
- REMEDIATED – Vulnerability has been remediated and is no longer detected by tool/sensors.

[CDM PMO] [REQUIRED]

NonCVEVULStatusJustification – An attribute that captures the justification for a discovered vulnerability having a status of "RISK ACCEPTED," [CDM PMO] [CONDITIONALLY REQUIRED] (***Note:*** *"Conditionally Required because a value for this attribute is only valid if the VULStatus is "RISK ACCEPTED."*).

OrganizationalUnitBoundary – An entity that captures an organization of any size, complexity, or positioning

within a hierarchal structure of a department or agency (see **OU** in Data Model Key Terms for additional context). The relationship between a Tier 0 OU and a Tier 1 OU is represented by a recursive relationship in the LDM. Recursive relationships are often used to represent hierarchies or networks, where an entity can be connected to other entities of the same type. [CDM PMO] [REQUIRED]

***Additional Context*:** This is the construct that provides the *OU containers* functionality that will provide a capability to group CDM objects of interest. At a *minimum,* the CDM solution shall be capable of providing OU containers that capture the first level of agency hierarchy organization (one OU within a department or agency). Refer to the *Organizational Unit Containers (OU Containers)* section for more information.

OrganizationalUnitBoundaryID – An attribute that captures a UID that identifies a specific OU boundary. [CDM PMO] [REQUIRED]

***Additional Context*:** Refer to the *Organizational Unit Containers (OU Containers) section*.

OrganizationalUnitName – An attribute that captures an agency-defined name for the organization. [CDM PMO] [REQUIRED]

OrganizationalUnitType – An attribute that captures the type of OU for use in determining the provider of the devices inventoried by CDM. The attribute shall be one of the following:

- GOVERNMENT – Devices assigned to this OU are GFE and are subject to this organization's policies.
- CONTRACTOR – Devices assigned to this OU are contractor-provided devices (non-GFE) and are subject to contractor oversight and associated policies.

[CDM PMO] [REQUIRED]

ResponseActivity – An entity that represents a specific activity in response to a suspected or confirmed incident on an agency's network. (See **Response Activity** in Data Model Key Terms for additional context.) [CDM PMO]

ResponseActivityDescription – An attribute that captures the related work, tasks, and actions associated with the **ResponseActivity** (e.g., isolate infected machines; capture memory/disk image; wipe and rebuild). [CDM PMO]

ResponseActivityID – An attribute that captures a unique identifier for each activity that occurs in response to a suspected or confirmed incident on an agency's network; this attribute helps an agency mitigate, triage, or otherwise remediate the impact of an incident. [CDM PMO]

ResponseActivityStartDate – An attribute that captures the date when the **ResponseActivity** was started. [CDM PMO]

ResponseActivityEndDate – An attribute that captures the date when the **ResponseActivity** was completed (if available). [CDM PMO]

SCuBAConnectFinding – An entity that captures data provided in a ScubaGear M365 and ScubaGoggles GWS report that gives visibility on agency risk posture to agencies. [CDM PMO] [REQUIRED]

SCuBAConnectFindingID – An attribute that captures a unique identifier assigned to each report. [CDM PMO] [REQUIRED]

SCuBAControlID – An attribute that captures the unique identifier string of a policy in a SCuBA Secure Configuration Baseline document. [CDM PMO] [REQUIRED]

SCuBACriticality – An attribute that captures the criticality of the SCuBA baseline policy. Based on RFC

2119, for example, SHALL means the policy is required, SHOULD means the policy is recommended. [CDM PMO] [REQUIRED]

SCuBADetails – An attribute that captures the details of how the tenant assessed either does or does not meet the SCuBA Secure Configuration Baseline policy requirement. [CDM PMO] [REQUIREMENT]

SCuBAProductSuite – An attribute that captures the name of the SCuBA baseline product suite that is being assessed with the current SCuBA tool. [CDM PMO]

SCuBAProductName – An attribute that captures the name of the SCuBA baseline product. [CDM PMO]

SCuBARequirement – An attribute that captures the SCuBA Secure Configuration Baseline document policy text that dictates to the user how a setting in a policy is to be configured. [CDM PMO] [REQUIRED]

SCuBAResult – An attribute that captures the decision made by the SCuBA assessment tool as to whether the tenant assessed meets the required configuration stated by the policy. [CDM PMO] [REQUIRED]

SCuBAScanDate – An attribute that captures the date and time the client ran a ScubaGear assessment. [CDM PMO]

SCuBAScanEntity – An attribute that captures information such as the Tenant.id, Tenant.domain, and Organization.id as identifying information assigned to each M365 tenant/GWS customer. [CDM PMO]

SCuBAScanToolName – An attribute that captures the name of the current SCuBA tool conducting the assessment. [CDM PMO]

SCuBAScanToolVersion – An attribute that captures the version of the current SCuBA tool conducting the assessment. [CDM PMO]

SoftwareInstalledOnDevice – An entity that represents a record of all installed software detected on a specific agency device. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because **software** attribute-level data requirements apply only when a device **hosts scanned software**.)*

SoftwareAuthorizationStatus – An attribute that captures an agency's policy assessment of whether software is authorized to be on a device on the network. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required"; expected through the AEC sub-capability.)*

SoftwareFirstDetected – An attribute that captures the date an instance of unique software was first inventoried (i.e., confirmed installed, "seen") on a specific device on an agency's network. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required.")*

SoftwareLastDetected – An attribute that captures the date a unique software was last inventoried (i.e., confirmed installed) on a specific device on an agency's network. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** See above for explanation of "conditionally required." This attribute should reflect the last time that this unique software asset was "seen" or updated through a discovery or scanning process. For example, if no relevant details about a software inventory record change, but it is still seen, this attribute would be updated with the last date the sensor witnessed the software.)*

SystemBoundary – An entity that captures a boundary, including all components of an information (FISMA) system to be authorized for operation by an authorizing official, and that excludes separately authorized systems to which the information system is connected. (See **System** in Data Model Key Terms for additional context.) The relationship between a system and a subsystem is represented by a recursive relationship in the

LDM. Recursive relationships are often used to represent hierarchies or networks, where an entity can be connected to other entities of the same type. [CDM PMO] [REQUIRED]

AuthorizationDecision – An attribute that captures whether a system boundary is authorized to operate. The **AuthorizationDecision** is a Yes/No value. (See **Authorization Decision** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

AuthorizationDecisionType – An attribute that captures the type of authorization a system boundary has for authorization status indication. Values for this attribute shall be only one of the following:

- ATO
- Common Control Authorization
- Authorization to Use
- Denial of Authorization

[CDM PMO] [REQUIRED]

***Additional Context*:** Refer to FY25 CIO Annual FISMA Metrics, metric 1.1.3 .

AuthorizationDecisionDate – An attribute that captures the date of the most recent authorization decision. [CDM PMO] [REQUIRED]

AuthorizationDecisionExpirationDate – An attribute that captures the date that the latest authorization decision expires. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because depending on the type of authorization decision (AuthorizationDecisionType), the ATO may not have an expiration date.)*

AuthorizationPreCondition – An attribute that captures a Boolean value for whether a System Boundary is "Awaiting Authorization" or not. [CDM PMO]

AuthorizationPostCondition – An attribute that captures a Boolean value for whether a System Boundary is "Awaiting Decommission" as an interim status. [CDM PMO]

AuthorizationType – An attribute that captures the type of authorization, which shall be only one of the following:

- Initial Authorization
- Ongoing Authorization
- Reauthorization

[CDM PMO] [CONDITIONALLY REQUIRED] *(Note: "Conditionally required" because these types may not apply to the given system boundary.)*

AuthorizingOfficial – An attribute that captures the name(s) of a senior federal official or executive with the authority to authorize (i.e., assume responsibility for) the operation of an information system or the use of a designated set of common controls at an acceptable level of risk to agency operations (including mission, functions, image, or reputation), agency assets, individuals, other organizations, and the nation. [NIST 800-53]

Availability – An attribute that captures the availability component of the FIPS 199 impact level. (See **FIPS 199 Impact Level Component: Availability** in Data Model Key Terms for additional context.) Values for this attribute shall be only one of the following:

- LOW
- MOD (moderate)
- HIGH

[CDM PMO] [REQUIRED]

Confidentiality – An attribute that captures the confidentiality component of the FIPS 199 impact level. (See **FIPS 199 Impact Level Component: Confidentiality** in Data Model Key Terms for additional context.) Values for this attribute shall be only one of the following:

- LOW
- MOD (moderate)
- HIGH

[CDM PMO] [REQUIRED]

ContractorName – An attribute that captures the name of the contractor organization that uses/operates the system boundary. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not work with contractor organization.)*

HVAFlag – An attribute that captures whether the Agency is identifying the FISMA system as containing high-value assets. [CDM PMO] [REQUIRED]

LastTimeAssessmentReviewed – An attribute that captures the review date of the most recent security assessment for the system boundary. [CDM PMO]

ImpactLevel – An attribute that captures the global FIPS 199 impact level across the confidentiality, integrity, and availability components. This attribute is synonymous with *"FIPS High Water Mark."* (See **FIPS 199 Impact Components** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

InitialAuthorizationDecisionDate – An attribute that captures the date of the initial authorization of the system boundary. [CDM PMO]

Integrity – An attribute that captures the integrity component of the FIPS 199 impact level (see **FIPS 199 Impact Level Component: Integrity** in Data Model Key Terms for additional context). Values for this attribute shall be only one of the following:

- LOW
- MOD (moderate)
- HIGH

[FIPS 199]

Subsystem – An attribute that identifies a major subdivision of an information system. It must be associated with at least one Systemboundary without the subsystem attribute. There may be multiple subsystems associated with one Systemboundary. This attribute is Boolean. [CDM PMO]

SystemBoundaryID – An attribute that captures a unique identifier that details a specific system boundary. This will be the unique key, name, or descriptor to identify a [FISMA] system for future reporting and reference. (See **System** in Data Model Key Terms for additional context.) [CDM PMO] [REQUIRED]

SystemBoundaryName – An attribute that captures the simple name of the system boundary for ease of practical identification and to enable the potential identification of the system business mission. [CDM PMO] [REQUIRED]

SystemBoundaryType - An attribute that captures the type of system boundary for use in determining if the system is used or operated by a contractor or an executive agency. The attribute shall be one of the following:

- CONTRACTOR – Systems used or operated by a contractor
- GOVERNMENT – Systems used or operated by an executive agency

[CDM PMO] [REQUIRED]

SystemOwner – An attribute that captures the full name of the organization official responsible for the procurement, development, integration, modification, operation, maintenance, and disposal of a system. The system owner is responsible for addressing the operational interests of the user community (i.e., users who require access to the system to satisfy mission, business, or operational requirements) and for ensuring compliance with security requirements. [NIST 800-37] [CDM PMO]

SystemInterconnection – An entity that captures information about direct connection(s) a given system boundary has with a separate system boundary. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not capture system interconnection information based on lack of tools.)*

ConnectedSystemName – An attribute that captures the simple name of the separate FISMA system boundary to which there is an interconnection. [CDM PMO] [REQUIRED]

InformationExchangeMethod – An attribute that captures the method of information exchange between the systems. [CDM PMO] [REQUIRED]

FIPSHighWaterMark – An attribute that captures the highest FIPS 199 categorization level across the confidentiality, integrity and availability spectrum of the separate system boundary to which there is an interconnection. Shall be one of the following values:

- LOW
- MODERATE
- HIGH

[CDM PMO] [REQUIRED]

SystemInterconnectionID – An attribute that captures a unique identifier for a FISMA system interconnection. [CDM PMO] [REQUIRED]

ThreatIntelligence – An entity that captures relevant information about available threat intelligence that has been correlated to some cyber-relevant information within the CDM system. [CDM PMO] [REQUIRED]

CVEAttackingEase – An attribute that captures the level of ease with which the CVE can be successfully exploited. [CDM PMO]

CVEExploit – An attribute that captures the level and severity of exploitation-related activity occurring "in the wild" for a specific CVE. [CDM PMO]

CVEMitigation – An attribute that captures the mitigation activities available for the CVE (e.g., implement web application firewall, patch). [CDM PMO]

CVERiskRating – An attribute that captures an expert assessment, sourced from threat intelligence sources, of a specific CVE's relative risk. [CDM PMO]

CVEVendorFix – An attribute that captures information (i.e., descriptions, URLs) relating to vendor-issued fix(es) or patches for the specific CVE. [CDM PMO] [REQUIRED]

IntelligenceReportIOC – An attribute that captures specific IOCs included in a threat intelligence feed report/product (e.g., file hashes, domain name, IP addresses, signatures). [CDM PMO]

IntelligenceReportName – An attribute that captures the name and/or title of a **ThreatIntelligence**. [CDM PMO]

IntelligenceReportPublishedDate – An attribute that captures the date threat intelligence was published by the originating source (e.g., vendor/provider, organization). [CDM PMO]

IntelligenceReportSummary – An attribute that captures the executive-level summary and/or findings of the threat intelligence. [CDM PMO]

IntelligenceReportType – An attribute that captures the type of threat intelligence that was correlated to CDM system information. The attribute may be one of the following:

- Vulnerability– Threat intelligence that is focused on specific vulnerabilities/CVEs.
- Threat– Threat intelligence that generically focuses on certain TTPs, actors, or active campaigns. [CDM PMO]

ThreatIntelligenceID – An attribute that captures a unique identifier for each threat intelligence feed report/product. [CDM PMO] [REQUIRED]

ToolSensorDeviceOnNetwork [*DeviceOnNetwork Specialization*] – An entity that captures the relevant information about CDM tools or sensors employed to capture cyber-relevant conditions or information (e.g., vulnerability, misconfiguration, etc.). **ToolSensorDeviceOnNetwork** is a specialization (subclass) of **DeviceOnNetwork** and serves a specific CDM-based role on the network. The information in this entity supports enumeration of cyber technologies that are used to perform CDM capabilities. [CDM PMO] [REQUIRED]

NVDLastUpdateDate – An attribute that captures the date the vulnerability or relevant components within the scanner (e.g., scanner definition data, plug-in updates) were last updated with the latest NVD-relevant information for scanning purposes. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some tools do not receive updates from NVD. Not all tools or sensors will require an NVD-relevant update activity. This attribute is vital for tools whose efficacy for detecting information (e.g., CVEs) is determined by how current its configuration files are.)*

ToolSensorProduct – This attribute captures the most common and recognizable title or name of the **ToolSensor** (e.g., Nessus® Professional). [CDM PMO] [REQUIRED]

ToolSensorType – An attribute that captures the CDM capability that the tool/sensor supports. The attribute can be one or more of the following values:

- VUL
- CSM
- MTD
- EMM
- HWAM

- SWAM

[CDM PMO] [REQUIRED]

ToolSensorVersion – This attribute captures the vendor-specified identification of the particular release version of the **ToolSensor** (e.g., version 6.10.5). [CDM PMO] [REQUIRED]

ToolSensorVendor – This attribute captures person or organization (e.g., corporation) that manufactured or created the product (e.g., Tenable Inc.). [CDM PMO] [REQUIRED]

UniqueSoftware – An entity that represents information about a software product inventory item that is discovered in an agency. (See **UniqueSoftware** in Data Model Key Terms for additional context.) [CDM Technical Capabilities, Vol. 2] [CDM PMO] [REQUIRED]

CommonProductName – An attribute that captures an alternate common name used to identify executable software discovered by CDM, such as an alias applied/used by an agency or colloquially used by OEM/industry (e.g., Microsoft Word 2013, Acrobat Pro 10). [CDM PMO] [REQUIRED]

Critical – An attribute that captures whether the software meets the critical software criteria as defined by NIST.[22] [EO 14028] [REQUIRED]

MobileAppBundleID – An attribute that captures the unique identifier of a mobile app—referred to as a "bundle ID" (iOS) or "package name" (Android)—on a mobile device or within a mobile app marketplace (i.e., Google Play, App Store). [CDM PMO]

MobileAppHash – This attribute captures the cryptographic hash of the app installed on a mobile device. [CDM PMO]

MonitoredSoftware – A (Boolean) attribute that flags the existence of software on a watch list. [CDM PMO] [REQUIRED]

MonitoredSoftwareSources – An attribute that lists the sources of the monitored software. [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because some agencies may not have a watch list.)*

SoftwareEdition – An attribute that captures the vendor-specified identification of the particular release edition of the product. [CDM PMO]

SoftwareProduct – This attribute captures the most common and recognizable title or name of the unique software product on an agency's network as defined by its CPE WFN or industry. [NIST Interagency Report (IR) 7695] [REQUIRED]

SoftwareType – An attribute that captures the type or general categorization of software being inventoried as reported by CDM tools/sensors (e.g., productivity, games, antivirus, web browser). [CDM PMO] [REQUIRED]

SoftwareUpdate – An attribute that captures the particular update, service pack, or point release of the product (e.g., Microsoft .NET Framework v3.5.1 Update SP1). [NIST IR 7695] [REQUIRED]

SoftwareVersion – An attribute that captures the vendor-specified identification of the particular release version of the product (e.g., McAfee VirusScan version 8.5i). [NIST IR 7695] [REQUIRED]

SoftwareVendor – An attribute that captures a person or organization (e.g., corporation) that manufactured or created the product. [NIST IR 7695] [REQUIRED]

[22] Definition of "Critical Software" can be found at Critical Software Definition | NIST.

UniqueSoftwareID – An attribute that captures a unique identifier that references a specific inventoried software in the CDM solution. [CDM PMO] [REQUIRED]

VDPSubmission – An entity that captures the submissions from ethical hackers or security researchers that identifies security vulnerabilities in an agency's public-facing systems. [CDM PMO] [REQUIRED]

VDPSubmissionDate – An attribute that captures the date of the submission. [CDM PMO]

VDPSubmissionDetails – An attribute that captures the desired identified details of the submission. [CDM PMO]

VDPSubmissionID – An attribute that captures a unique identifier assigned to each submission. [CDM PMO] [REQUIRED]

VDPSubmissionSeverity – An attribute that captures the severity (CRITICAL, SEVERE, MODERATE, LOW, INFORMATIONAL) of the vulnerability being reported. The value of this attribute shall be one of the following:

- CRITICAL
- SEVERE
- MODERATE
- LOW
- INFORMATIONAL

[CDM PMO] [REQUIRED]

VDPSubmissionValidated – An attribute that captures a Boolean value indicating whether a reported vulnerability is determined to be valid. [CDM PMO] [REQUIRED]

VDPSubmissionVULStatus – An attribute that captures the status of a reported vulnerability submission. The value of this attribute shall be one of the following:

- Informational
- New
- Not Applicable
- Not Reproducible
- Out of Scope
- Triaged
- Unresolved
- Resolved

[CDM PMO] [REQUIRED]

VulnerabilityOnNetwork – An entity that represents a single discovered vulnerability within an agency, which is further defined as a CVE that exists on software installed on an agency device and detected by a CDM tool or sensor. The scope of applicable CVEs that can constitute a software-based vulnerability includes information available in the NVD. [CDM PMO] [REQUIRED]

DateOfVULScan – An attribute that captures the date of the last (most recent) vulnerability scan that

found the vulnerability on a device within the agency's network. [CDM PMO] [REQUIRED] (***Note:*** *This attribute should reflect the last time that a vulnerability was "seen" or updated through a scanning process. If no new relevant details about a vulnerability are discovered but the vulnerability is still seen, this attribute would be updated with the last date the sensor witnessed the vulnerability*.)

VULConfirmedFalsePositive – An attribute that captures, in a Boolean value, whether a vulnerability is a confirmed false positive due to misconfigurations, tool/sensor issues, or other reasons. [CDM PMO]

VULID – An attribute that captures a unique identifier referencing a specific discovered vulnerability on an agency's network. [CDM PMO] [REQUIRED]

VulnerableSoftwareVendorName – An attribute that captures the software vendor name of the vulnerable software. [CDM PMO] [REQUIRED]

VulnerableSoftwareCommonProductName – An attribute that captures the common product name of the vulnerable software. [CDM PMO] [REQUIRED]

VulnerableSoftwareVersion – An attribute that captures the software version of the vulnerable software. [CDM PMO] [REQUIRED]

VulnerableSoftwareCVEDetectionSignatureIdentifier – An attribute that captures a vendor-provided value that identifies the software module(s) used by the VUL tool to detect the vulnerability. [CDM PMO] [REQUIRED]

VulnerableSoftwareInstallationFilePath – An attribute that captures the installation location of the vulnerable software. [CDM PMO] [REQUIRED]

VULFixText – An attribute provided by the VUL tool that captures the clear and simple description of how to correct the vulnerability; this shall include the version of the software that remediates the vulnerability. [CDM PMO] [REQUIRED]

VULOriginalDiscoveryDate – An attribute that captures the date when the **VulnerabilityOnNetwork** was first discovered. [CMD PMO] [REQUIRED]

VULRemediationDate – An attribute that captures the date a vulnerability was remediated (e.g., vulnerable software patched or removed). [CDM PMO] [CONDITIONALLY REQUIRED] *(**Note:** "Conditionally required" because the vulnerability may not yet be remediated.)*

VULStatus – An attribute that captures the status of a particular **VulnerabilityOnNetwork**. The attribute shall be one of the following:

- OPEN
- RISK ACCEPTED – Vulnerability has currently been accepted and is not expected to be remediated due to some exigent circumstances.
- REMEDIATED – Vulnerability has been remediated and is no longer detected by tool/sensors.

[CDM PMO] [REQUIRED]

VULStatusJustification – An attribute that captures the justification for a discovered vulnerability having a status of "RISK ACCEPTED". [CDM PMO] [CONDITIONALLY REQUIRED] (***Note:*** *"Conditionally Required because a value for this attribute is only valid if the VULStatus is "RISK ACCEPTED".*)

APPENDIX A: REFERENCES

Barker, Elaine. 2020. "Recommendation for Key Management: Part 1- General." *NIST Special Publication 800-57 Part 1 Revision 5.*

Brant Cheikes (MITRE), David Waltermire (NIST), Karen Scarfone (Scarfone Cybersecurity). 2011. "Managing Information Security Risk: Organization, Mission, and Information System View." *NIST SP 800-39.*

CAPEC. 2021. *CAPEC LIST VERSION 3.9.* October 21. https://capec.mitre.org/data/index.html.

CDM. *CDM Dashboard Data Target.* Accessed August 2023. https://confluence.cdmdashboard.com/display/CDE/Dashboard+Data+Target. (registration required).

CISA. *Cyber Hygiene Services*. Accessed August 2023. https://www.cisa.gov/cyber-hygiene-services.

CISA. 2017. *Federal Incident Notification Guidelines*. April 1. https://www.cisa.gov/incident-notification-guidelines.

CISA. 2021. "FY 2021 CIO FISMA Metrics," Version 1.1. August. https://www.cisa.gov/sites/default/files/publications/FY_2021_FISMA_CIO_Metrics-v1.1.pdf.

CISA. 2025. "FY 2025 CIO FISMA Metrics," Version 1.1. December 2024. https://www.cisa.gov/sites/default/files/2025-01/FY25-FISMA-CIO-Metrics-v1.1.pdf.

CISA. 2018. *BOD 18-02*: *Securing High Value Assets.* May 7. https://www.cisa.gov/news-events/directives/bod-18-02-securing-high-value-assets.

CISA. 2019. *BOD 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems.* April 29. https://www.cisa.gov/news-events/directives/bod-19-02-vulnerability-remediation-requirements-internet-accessible-systems.

CISA. 2025. BOD 25-01: Implementing Secure Practices for Cloud Services. May 27. https://www.cisa.gov/news-events/directives/bod-25-01-implementation-guidance-implementing-secure-practices-cloud-services.

2017. "Continuous Diagnostics and Mitigation Technical Capabilities." Volume 1: Defining Actual and Desired States.

2023. "Continuous Diagnostics and Mitigation Technical Capabilities." Volume Two: Requirements Catalog," Version 2.5.

D. Cooper NIST, S. Santesson. 2008. "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile." Internet Standards.

2017. *Federal Incident Notification Guidelines.* April 1. https://www.cisa.gov/federal-incident-notification guidelines.

Fenton, Paul A. Grassi Michael E. Garcia James L. 2017. "Digital Identity Guidelines." *NIST Special Publication 800-63-3.*

2004. "FIPS Pub 199." *Standards for Security Categorization of Federal Incident Notification Guidelines.* February.

FORCE, JOINT TASK. 2022. "Assessing Security and Privacy Controls in Information Systems and Organizations." *NIST Special Publication 800-53A.*

FORCE, JOINT TASK. 2018. "Risk Management Framework for Information Systems and Organizations."

FORCE, JOINT TASK. 2013. "Security and Privacy Controls for Federal Information Systems." *NIST Special Publication 800-53.*

Handbook, Department of Homeland Security Sensitive Policy. 2023. *DHS Sensitive Systems Policy Documents (4300A).* May 31.

Initiative, Joint Task Force Transformation. 2019. “Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach. *NIST SP 800-37.*

Initiative, Joint Task Force Transformation. 2011. "Managing Information Security Risk: Organization, Mission, and Information System View." *NIST SP 800-39.*

Initiative, Joint Task Force Transformation. 2012. "NIST SP 800-30 Rev. 1 Guide for Conducting Risk Assessments."

Kelley Dempsey (NIST), Nirali Chawla (PwC), L. Johnson (NIST), Ronald Johnston (DoD), Alicia Jones (BAH), Angela Orebaugh (BAH), Matthew Scholl (NIST), Kevin Stine (NIST). 2011. "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations." 80.

2017. *Malware Attribute Enumeration and Characterization.* October 9. https://maecproject.github.io/.

Marianne Swanson (NIST), Joan Hash (NIST), Pauline Bowen (NIST). 2006. "Guide for Developing Security Plans for Federal Information Systems."

Paul Cichonski. Tom Millar, Tim Grance, Karen Scarfone. 2012. "Recommendations of the National Institute of Standards and Technology." *Computer Security Handling Guide.*

Veris. n.d. *the vocabulary for event recording and incident sharing.* Accessed July 2023. https://verisframework.org/.

APPENDIX B: THREAT ACTION VALUES

ThreatActionVariety Values for **ThreatActionCategory** = "MALWARE"

ThreatActionVariety Value	Description
ADMINWARE	System or network utilities (e.g., PsTools, Netcat). [VERIS]
ADWARE	Any software that is funded by advertising. Adware may also gather sensitive user information from a system. [VERIS] [MAEC]
APPENDER	File-infecting malware that places its code at the end of the files it infects, adjusting the file's entry point to cause its code to be executed before that in the original file. [MAEC]
BACKDOOR	Malware which, once running on a system, opens a communication vector to the outside so the computer can be accessed remotely by an attacker. [VERIS] [MAEC]
BOOT-SECTOR-VIRUS	Malware that infects the master boot record of a storage device. [MAEC]
BRUTE FORCE	Brute force attack. [VERIS]
CAPTURE APP DATA	Capture data from application or system process. [VERIS]
CAPTURE STORED DATA	Capture data stored on system disk. [VERIS]
CAVITY-FILLER	A type of file-infecting virus that seeks unused space within the files it infects, inserting its code into these gaps to avoid changing the size of the file and thus not alerting integrity-checking software to its presence. [MAEC]
CLICKER	A Trojan that makes a system visit a specific web page, often very frequently and usually with the aim of increasing the traffic recorded by the site and thus increasing revenue from advertising. Clickers may also be used to carry out DDoS attacks. [MAEC]
COMPANION-VIRUS	A virus that takes the place of a particular file on a system instead of injecting code into it. [MAEC]
CLIENT-SIDE ATTACK	Client-side or browser attack (e.g., redirection, XSS, MitB). [VERIS]
CLICK FRAUD	Click fraud or Bitcoin mining. [VERIS]
C2	Command and control (C2). [VERIS]
DATA-DIDDLER	A type of malware that makes small, random changes to data, such as data in a spreadsheet, to render the data contained in a document inaccurate and in some cases worthless. [MAEC]
DESTROY DATA	Destroy or corrupt stored data. [VERIS]
DISABLE CONTROLS	Disable or interfere with security controls. [VERIS]
DDOS/DOS	A tool used to perform a distributed denial of service attack. [VERIS] [MAEC]
DOWNLOADER	Downloader (pull updates or other malware): malware programmed to download and execute other files, usually more complex malware. [VERIS] [MAEC]
DROPPER	A type of Trojan that deposits an enclosed payload onto a destination host computer by loading itself into memory, extracting the malicious payload, and then writing it to the file system. [MAEC]
EXPLOIT-KIT / EXPLOIT VULN	A software toolkit to target common vulnerabilities. [VERIS] [MAEC]

ThreatActionVariety Value	Description
EXPORT DATA	Export data to another site or system. [VERIS]
FILE-INFECTOR-VIRUS	A virus that infects a system by inserting itself somewhere in existing files; this is the "classic" form of virus. [MAEC]
FILE-LESS	Malware that is file-less, i.e., executes through some other mechanism such as PowerShell. [MAEC]
FORK-BOMB	A simple form of malware, a type of rabbit which launches more copies of itself. Once a fork-bomb is executed, it will attempt to run several identical processes, which will do the same, the number growing exponentially until the system resources are overwhelmed by the number of identical processes running, which may in some cases bring the system down and cause a denial of service. [MAEC]
GREYWARE	Software that, while not definitely malicious, has a suspicious or potentially unwanted aspect. [MAEC]
IMPLANT	Code inserted into an existing program using a code patcher or other tool. [MAEC]
KEYLOGGER	A type of program implanted on a system to monitor the keys pressed and thus record any sensitive data, such as passwords, entered by the user. [MAEC] [VERIS]
KLEPTOGRAPHIC-WORM	A worm that encrypts information assets on compromised systems so they can only be decrypted by the worm's author; also known as information-stealing worm. [MAEC]
MACRO-VIRUS	A virus that uses a macro language, for example in Microsoft Office documents. [MAEC]
MALWARE-AS-A-SERVICE	Malware that is sold or produced as a service. [MAEC]
MASS-MAILER	A worm that uses email to propagate across the internet. [MAEC]
METAMORPHIC-VIRUS	A virus that changes its own code with each infection. [MAEC]
MULTIPARTITE-VIRUS	Malware that infects boot records, boot sectors, and files. [MAEC]
MID-INFECTOR	A type of file-infecting virus which places its code in the middle of files it infects. It may move a section of the original code to the end of the file or simply push the code aside to make space for its own code. [MAEC]
MOBILE-CODE	Either (a) code received from remote, possibly untrusted systems, but executed on a local system or (b) software transferred between systems (e.g., across a network) and executed on a local system without explicit installation or execution by the recipient. [MAEC]
MULTIPARTITE-VIRUS	Malware that infects boot records, boot sectors, and files. [MAEC]
PARENTAL-CONTROL	A program that monitors or limits machine usage. Such programs can run undetected and can transmit monitoring information to another machine. [MAEC]
PACKET SNIFFER	Packet sniffer (capture data from network). [VERIS]
PASSWORD-STEALER / PASSWORD DUMPER	A type of Trojan designed to steal passwords (or extract credential hashes), personal data and details, or other sensitive information from an infected system. [VERIS] [MAEC]
POLYMORPHIC-VIRUS	A type of virus that encrypts its code differently with each infection (or with each generation of infections). [MAEC]
PREMIUM-DIALER-SMSER	A type of malware whose primary aim is to dial (or send SMS messages to) premium rate numbers. [MAEC]

ThreatActionVariety Value	Description
PREPENDER	A file-infecting virus that inserts code at the beginning of the files it infects. [MAEC]
RAM SCRAPER	Ram scraper or memory parser (capture data from volatile memory). [VERIS]
RANSOMWARE	Ransomware (encrypt or seize stored data): malware that encrypts files on a victim's system, demanding payment of ransom in return for the access codes required to unlock files. [VERIS] [MAEC]
REMOTE-ACCESS-TROJAN (RAT)	A remote access Trojan program, or RAT, is a Trojan horse capable of controlling a machine through commands issued by a remote attacker. [MAEC]
RESOURCE-EXPLOITER	A type of malware that steals a system's resources (e.g., CPU cycles), such as a bitcoin miner. [MAEC]
ROGUE-SECURITY-SOFTWARE	A fake security product that demands money to clean phony infections. [MAEC]
ROOTKIT	Rootkit (maintain local privileges and stealth): A method of hiding files or processes from normal methods of monitoring; often used by malware to conceal its presence and activities. [VERIS] [MAEC]
SCAN NETWORK	Scan or footprint network. [VERIS]
SCAREWARE	A program that reports false or significantly misleading information on the presence of security risks, threats, or system issues on the target computer. [MAEC]
SCREEN-CAPTURE	A type of malware used to capture images from the target systems screen, used for exfiltration and command and control. [MAEC]
SECURITY-ASSESSMENT-TOOL	A program that can be used to gather information for unauthorized access to computer systems. [MAEC]
SHELLCODE	Either (a) a small piece of code that activates a command-line interface to a system that can be used to disable security measures, open a backdoor, or download further malicious code or (b) a small piece of code that opens a system up for exploitation, sometimes by not necessarily involving a command-line shell.
SPAM	Send spam. [VERIS]
SPYWARE	Software that gathers information and passes it to a third-party without adequate permission from the owner of the data. It may also refer to software that makes changes to a system or any of its component software, or which makes use of system resources without the full understanding and consent of the system owner. [MAEC] [VERIS]
SQL INJECTION	SQL injection attack. [VERIS]
TRACKWARE	Malware that traces a user's path on the internet and sends information to third parties. Compare to spyware, which monitors system activity to capture confidential information such as passwords.
TROJAN	Malware disguised as something inert or benign. [VERIS]
VIRUS	Self-replicating malware that requires human interaction to spread; also, self-replicating malware that runs and spreads by modifying and inserting itself into other programs or files. [MAEC]

ThreatActionVariety Value	Description
WEB-BUG	Code embedded in a web page or email that checks whether a user has accessed the content (e.g., a tiny, transparent GIF image). [MAEC]
WIPER	Malware that deletes files or entire disks on a machine. [MAEC]
WORM	Self-replicating malware that propagates across a network either with or without human interaction. [VERIS] [MAEC]
UNKNOWN	Unknown [VERIS]
OTHER	Other [VERIS]

ThreatActionMethod Values for **ThreatActionCategory** = "MALWARE"

ThreatActionMethod Value	Description
AUTO-EXECUTING-MEDIA	The malware instance or family was delivered via media that automatically executes. [MAEC]
DIRECT INSTALL [VERIS] / ACTIVE ATTACKER [MAEC]	Directly installed or inserted by threat agent/attacker (after system access). [VERIS] [MAEC]
DOWNLOAD BY MALWARE [VERIS] / DOWNLOADER [MAEC]	Downloaded and installed by local malware, delivered by downloader. [VERIS] [MAEC]
DROPPER	The malware instance or family was delivered via dropper.
EMAIL AUTOEXECUTE	Email via automatic execution. [VERIS]
EMAIL LINK	Email via embedded link. [VERIS]
EMAIL ATTACHMENT	Email via user-executed attachment. [MAEC] [VERIS]
EXPLOIT-KIT-LANDING-PAGE	The malware instance or family was delivered via an exploit kit landing page. [MAEC]
FAKE-WEBSITE	The malware instance or family was delivered via a fake website. [MAEC]
INSTANT MESSAGING	Instant messaging [VERIS]
JANITOR-ATTACK	The malware instance or family was delivered via a janitor attack. [MAEC]
MALICIOUS-IFRAMES	The malware instance or family was delivered via malicious iframes. [MAEC]
MEDIA-BAITING	The malware instance or family was delivered via media baiting. [MAEC]
NETWORK PROPAGATION	Network propagation [VERIS]
PHARMING	The malware instance or family was delivered via pharming. [MAEC]
PHISHING	The malware instance or family was delivered via phishing. [MAEC]
REMOTE INJECTION	Remotely injected by agent (i.e., via SQLi). [VERIS]
REMOVABLE MEDIA	Removable storage media or devices. [VERIS]
TROJANIZED-LINK	The malware instance or family was delivered via a trojanized link. [MAEC]
TROJANIZED-SOFTWARE	The malware instance or family was delivered via trojanized software. [MAEC]
WEB DRIVE-BY [VERIS] / MALVERTISING [MAEC]	Web via auto-executed or "drive-by" infection (e.g., delivered via malvertising.) [VERIS] [MAEC]
WEB DOWNLOAD	Web via user-executed or downloaded content. [VERIS]
WATERING-HOLE	The malware instance or family was delivered via a watering hole. [MAEC]
UNKNOWN	Unknown [VERIS]
USB-CABLE-SYNCING	The malware instance or family was delivered via USB cable syncing. [MAEC]
OTHER	Other [VERIS]

ThreatActionVariety Values for **ThreatActionCategory** = "HACKING" [VERIS]

ThreatActionVariety Value	Description
ABUSE OF FUNCTIONALITY	Abuse of functionality
BRUTE FORCE	Brute force or password guessing attacks
BUFFER OVERFLOW	Buffer overflow
CACHE POISONING	Cache poisoning
SESSION PREDICTION	Credential or session prediction
CSRF	Cross-site request forgery
XSS	Cross-site scripting
CRYPTANALYSIS	Cryptanalysis
DOS	Denial of service
FOOTPRINTING	Footprinting and fingerprinting
FORCED BROWSING	Forced browsing or predictable resource location
FORMAT STRING ATTACK	Format string attack
FUZZ TESTING	Fuzz testing
HTTP REQUEST SMUGGLING	HTTP request smuggling
HTTP REQUEST SPLITTING	HTTP request splitting
INTEGER OVERFLOWS	Integer overflows
LDAP INJECTION	LDAP injection
MAIL COMMAND INJECTION	Mail command injection
MITM	Man-in-the-middle attack
NULL BYTE INJECTION	Null byte injection
OFFLINE CRACKING	Offline password or key cracking (e.g., rainbow tables, Hashcat, JtR)
OS COMMANDING	OS commanding
PATH TRAVERSAL	Path traversal
RFI	Remote file inclusion
REVERSE ENGINEERING	Reverse engineering
ROUTING DETOUR	Routing detour
SESSION FIXATION	Session fixation
SESSION REPLAY	Session replay
SOAP ARRAY ABUSE	Soap array abuse
SPECIAL ELEMENT INJECTION	Special element injection
SSI INJECTION	SSI injection
URL REDIRECTOR ABUSE	URL redirector abuse
USE OF BACKDOOR OR C2	Use of backdoor or C3
USE OF STOLEN CREDS	Unauthorized use of credentials
XML ATTRIBUTE BLOWUP	XML attribute blowup
XML ENTITY EXPANSION	XML entity expansion
XML EXTERNAL ENTITIES	XML external entities
XML INJECTION	XML injection

ThreatActionVariety Value	Description
XPATH INJECTION	XPath injection
XQUERY INJECTION	Xquery injection
VIRTUAL MACHINE ESCAPE	Virtual machine escape
UNKNOWN	Unknown
OTHER	Other

ThreatActionMethod Values for **ThreatActionCategory** = "HACKING" [VERIS]

ThreatActionMethod Value	Description
3RD PARTY DESKTOP	Third-party online desktop sharing (LogMeIn, Go2Assist)
BACKDOOR OR C2	Backdoor or command and control channel
DESKTOP SHARING	Graphical desktop sharing (RDP, VNC, PCAnywhere, Citrix)
PHYSICAL ACCESS	Physical access or connection (i.e., at keyboard or via cable)
COMMAND SHELL	Remote shell
PARTNER	Partner connection or credential
VPN	VPN
WEB APPLICATION	Web application
UNKNOWN	Unknown
OTHER	Other

ThreatActionVariety Values for **ThreatActionCategory** = "SOCIAL" [VERIS]

ThreatActionVariety Value	Description
BAITING	Baiting (planting infected media)
BRIBERY	Bribery or solicitation
ELICITATION	Elicitation (subtle extraction of info through conversation)
EXTORTION	Extortion or blackmail
FORGERY	Forgery or counterfeiting (fake hardware, software, documents, etc.)
INFLUENCE	Influence tactics (leveraging authority or obligation, framing, etc.)
SCAM	Online scam or hoax (e.g., scareware, 419 scam, auction fraud)
PHISHING	Phishing (or any type of *ishing)
PRETEXTING	Pretexting (dialogue leveraging invented scenario)
PROPAGANDA	Propaganda or disinformation
SPAM	Spam (unsolicited or undesired email and advertisements)
UNKNOWN	Unknown
OTHER	Other

ThreatActionMethod Values for **ThreatActionCategory** = "SOCIAL" [VERIS]

ThreatActionMethod Value	Description
DOCUMENTS	Documents
EMAIL	Email
IN-PERSON	In-person
IM	Instant messaging
PHONE	Phone
REMOVABLE MEDIA	Removable storage media
SMS	SMS or texting
SOCIAL MEDIA	Social media or networking
SOFTWARE	Software
WEBSITE	Website
UNKNOWN	Unknown
OTHER	Other

ThreatActionVariety Values for **ThreatActionCategory** = "MISUSE" [VERIS]

ThreatActionVariety Value	Description
KNOWLEDGE ABUSE	Abuse of private or entrusted knowledge
PRIVILEGE ABUSE	Abuse of system access privileges
EMBEZZLEMENT	Embezzlement, skimming, and related fraud
DATA MISHANDLING	Handling of data in an unapproved manner
EMAIL MISUSE	Inappropriate use of email or IM
NET MISUSE	Inappropriate use of network or web access
ILLICIT CONTENT	Storage or distribution of illicit content
UNAPPROVED WORKAROUND	Unapproved workaround or shortcut
UNAPPROVED HARDWARE	Use of unapproved hardware or devices
UNAPPROVED SOFTWARE	Use of unapproved software or services
UNKNOWN	Unknown
OTHER	Other

ThreatActionMethod Values for **ThreatActionCategory** = "MISUSE" [VERIS]

ThreatActionMethod Value	Description
PHYSICAL ACCESS	Physical access within corporate facility
LAN ACCESS	Local network access within corporate facility
REMOTE ACCESS	Remote access connection to corporate network (i.e., VPN)
NON-CORPORATE	Non-corporate facilities or networks
UNKNOWN	Unknown
OTHER	Other

ThreatActionVariety Values for **ThreatActionCategory** = "ERROR" [VERIS]

ThreatActionVariety Value	Description
CLASSIFICATION ERROR	Classification or labeling error
DATA ENTRY ERROR	Data entry error
DISPOSAL ERROR	Disposal error
GAFFE	Gaffe (social or verbal slip)
LOSS	Loss or misplacement
MAINTENANCE ERROR	Maintenance error
MISCONFIGURATION	Misconfiguration
MISDELIVERY	Misdelivery (direct or deliver to wrong recipient)
MISINFORMATION	Misinformation (unintentionally giving false info)
OMISSION	Omission (something intended, but not done)
PHYSICAL ACCIDENTS	Physical accidents (e.g., drops, bumps, spills)
CAPACITY SHORTAGE	Poor capacity planning
PROGRAMMING ERROR	Programming error (flaws or bugs in custom code)
PUBLISHING ERROR	Publishing error (private info to public doc or site)
MALFUNCTION	Technical malfunction or glitch
UNKNOWN	Unknown
OTHER	Other

ThreatActionMethod Values for **ThreatActionCategory** = "ERROR" [VERIS]

ThreatActionMethod Value	Description
RANDOM ERROR	Random error (no reason, no fault)
CARELESSNESS	Carelessness
INADEQUATE PERSONNEL	Inadequate or insufficient personnel
INADEQUATE PROCESSES	Inadequate or insufficient processes
INADEQUATE TECHNOLOGY	Inadequate or insufficient technology resources
UNKNOWN	Unknown
OTHER	Other

ThreatActionVariety Values for **ThreatActionCategory** = "PHYSICAL" [VERIS]

ThreatActionVariety Value	Description
ASSAULT	Assault (threats or acts of physical violence)
SABOTAGE	Sabotage (deliberate damaging or disabling action)
SNOOPING	Snooping (sneak about to gain info or access)
SURVEILLANCE	Surveillance (monitoring and observation)
TAMPERING	Tampering (alter physical form or function)
THEFT	Theft (taking assets without permission)
WIRETAPPING	Wiretapping (physical tap to comms line)
UNKNOWN	Unknown
OTHER	Other

ThreatActionMethod Values for **ThreatActionCategory** = "PHYSICAL" [VERIS]

ThreatActionMethod Value	Description
PRIVILEGED ACCESS	Held privileged access to location
VISITOR PRIVILEGES	Given temporary visitor access
BYPASSED CONTROLS	Bypassed physical barriers or controls
DISABLED CONTROLS	Disabled physical barriers or controls
UNCONTROLLED LOCATION	The location was uncontrolled (public)
UNKNOWN	Unknown
OTHER	Other

ThreatActionVariety Values for **ThreatActionCategory** = "ENVIRONMENTAL" [VERIS]

ThreatActionVariety Value	Description
DETERIORATION	Deterioration and degradation
EARTHQUAKE	Earthquake
EMI	Electromagnetic interference (EMI)
ESD	Electrostatic discharge (ESD)
TEMPERATURE	Extreme temperature
FIRE	Fire
FLOOD	Flood
HAZMAT	Hazardous material
HUMIDITY	Humidity
HURRICANE	Hurricane
ICE	Ice: Ice and snow
LANDSLIDE	Landslide
LIGHTNING	Lightning
METEORITE	Meteorite
PARTICULATES	Particulate matter (e.g., dust, smoke)
PATHOGEN	Pathogen
POWER FAILURE	Power failure or fluctuation
TORNADO	Tornado
TSUNAMI	Tsunami
VERMIN	Vermin
VOLCANO	Volcanic eruption
LEAK	Water leak
WIND	Wind
UNKNOWN	Unknown
OTHER	Other

APPENDIX C: RELEASE NOTES FOR THIS VERSION

This appendix lists the specific changes made in this version of the CDM Data Model Document (DMD) compared to the last public release. It helps readers quickly find the most recent relevant updates without needing to review the entire document.

General

1. Made requested updates that did not make it into CDM DMD v5.0.
2. Updates to align with latest FY25 FISMA Metrics, which included major changes to metrics and query considerations.

Section 2 CDM Guidance in Interpreting the Data Model

1. Removed section of Master User Record: Unique Identification of People
2. Added ASM, SCuBa and VDP Datasets

Section 3 Data Model Key Terms

1. Added IoT, OT, and ICS.
2. NCATS references changed to CyHy (Cyber Hygiene) to reflect updated convention.
3. Updated definition of ***System*** to include description of "subsystem" information capture.
4. Added Critical Software, Known Exploited Vulnerabilities (KEV).
5. Deleted Device Manager, Device Operator, Security Content Automation Protocol (SCAP) Validation.

Section 4 Data Dictionary for the Logical Data Model

1. Updated entity **CVEDictionary.**
    a. Added attribute ***KEVDateAdded***.
    b. Added attribute ***KEVDescription.***
    c. Added attribute ***KEVDueDate.***
    d. Added attribute ***KEVInCatalogue.***
    e. Added attribute ***KEVRequiredAction.***
    f. Added attribute ***KEVNotes.***
2. Removed ***DeviceManager*** and ***DeviceOperator*** entities.
3. Updated entity DeviceOnNetwork (including update of ***DeviceCategory*** and ***DeviceType*** based on FY24 CIO FISMA Metrics).
    a. Added attribute ***DeviceOS.***
    b. Updated attribute ***DeviceStatus.***
4. Updated entity ***DeviceScan.***
    a. Updated attribute ***CSMSettingsCount.***
    b. Updated attribute ***DeviceScanAuthOutcome.***
    c. Added attribute ***DeviceScanMethod.***

d. Updated attribute ***DeviceScanType*** (included MTD and EMM).

e. Added attribute ***ScanBenchmarkName.***

f. Added attribute ***ScanBenchmarkRelease.***

g. Added attribute ***ScanBenchmarkVersion.***

5. Updated entity ***SystemBoundary.***

a. Updated attribute ***AuthorizationDecisionType*** with more accurate type list.

b. Updated attribute ***AuthorizationDecisionExpirationDate*** to conditionally required.

c. Added attribute ***AuthorizationType.***

d. Added attribute ***AuthorizingOfficial.***

e. Added attribute ***HVAFlag.***

f. Added attribute ***Subsystem.***

g. Added attribute ***SystemBoundaryName.***

h. Added attribute ***SystemOwner.***

6. Updated entity ***UniqueSoftware.***

a. Removed attribute ***CPEInfo.***

b. Added attribute ***Critical.***

c. Added attribute ***SoftwareEdition.***

d. Added attribute ***SoftwareSupportStatus.***

7. Updated entity ***VulnerabilityOnNetwork.***

a. Updated attribute ***VulnerableSoftwareInfo*** to describe capture of Plugin info.

b. Update attribute ***VULFixText*** to more accurate description of attribute.

Section 5 CDM PMO Deprecated Attributes.

1. CCEAllowableTolerance
2. CVEAllowableTolerance
3. CVEAgingImpact